

Marketing SEO und Google Consent

SEO-Programm, Content-Pakete, Social Media und Google-Marketing-Integration

Die Wachstumsebene: SEO-Maßnahmen und Soft-404-Analysen, die Content-Strategie mit fertigen Content-Paketen inklusive Voiceover- und Thread-Vorlagen, Social-Media-Publishing sowie die geschützte Google-Marketing-, Analytics- und Consent-Integration. Dieses Bündel eignet sich besonders als Vorlage für Podcast- und Video-Formate.

Repository: SvenKulesa/Finance

Stand: claude/pdf-dokumente-notebook-lm-l6kcxq @ 4eadf9d

Erzeugt am: 16.08.2026

Enthaltene Dokumente: 27

Umfang: ca. 20.296 Wörter

Dieses PDF ist eine Quelle für NotebookLM. Jedes eingebettete Dokument beginnt auf einer neuen Seite und nennt seinen Repository-Pfad, damit erzeugte Podcasts, Video-Skripte und Zusammenfassungen ihre Aussagen exakt auf die Originaldatei zurückführen können.

Inhalt dieses Quellpakets

1. CAPITAL-AI — Enterprise Google Analytics Provisioner MCP	4
docs/architecture/CAPITAL_AI_ENTERPRISE_GOOGLE_ANALYTICS_MCP_IMPLEMENTATION.md	
2. CAPITAL-AI — Google Marketing MCP Architecture	53
docs/architecture/CAPITAL_AI_GOOGLE_MARKETING_MCP_ARCHITECTURE.md	
3. CAPITAL AI GOOGLE MARKETING MCP TOPOLOGY	64
docs/architecture/CAPITAL_AI_GOOGLE_MARKETING_MCP_TOPOLOGY.md	
4. Brand Persona, Copywriting & Content-Strategie	68
docs/content-creator/CONTENT_STRATEGY.md	
5. Affiliate / Referral Block (Owner-requested)	70
docs/content-creator/packages/graham-fair-value-check/AFFILIATE_REFERRAL.md	
6. ContentPackage — Benjamin Graham Fair Value Check bei CAPITAL-AI	71
docs/content-creator/packages/graham-fair-value-check/CONTENT_PACKAGE.md	
7. Media-Prompts & Produktionsanweisungen	76
docs/content-creator/packages/graham-fair-value-check/MEDIA_PROMPTS.md	
8. Controlled Publish-Plan	78
docs/content-creator/packages/graham-fair-value-check/PUBLISH_PLAN.md	
9. Content Package: Benjamin Graham Fair Value Check bei CAPITAL-AI	79
docs/content-creator/packages/graham-fair-value-check/README.md	
10. Voiceover-Script — Langes YouTube-Video (ca. 3:40 Min)	80
docs/content-creator/packages/graham-fair-value-check/VOICEOVER_YOUTUBE_LONG.md	
11. X – Kompletter Post + Short-Video: Imagine auf X	83
docs/content-creator/packages/graham-fair-value-check/X_IMAGINE_SHORT.md	
12. X (Twitter) Thread — Copy-Paste	85
docs/content-creator/packages/graham-fair-value-check/X_THREAD.md	
13. SEO D3 — Soft-404 Behoben	87
docs/seo/D3_SOFT_404.md	
14. SEO Block D (+ Q2 completion) — Implementation Notes	89
docs/seo/D_BLOCK_IMPLEMENTATION_NOTES.md	
15. Übergabe — WP-S1 SeoEngine an nächsten Bearbeiter (Grok)	91
docs/seo/HANDOFF_WP_S1_NEXT_2026-08-15.md	
16. SEO N4 — Content-Freigabe vor Publish	94
docs/seo/N4_CONTENT_APPROVAL.md	
17. SEO Q3 — Google Search Console Property verifizieren	96
docs/seo/Q3_SEARCH_CONSOLE_VERIFY_RUNBOOK.md	

18. SEO Block Q — Implementation Notes (2026-08-15)	98
docs/seo/Q_BLOCK_IMPLEMENTATION_NOTES.md	
19. SEO S1 / WP-S1 — SeoEngine Foundation & Persistenz	100
docs/seo/S1_SEO_ENGINE.md	
20. SEO S2 — Public Route Prerender	102
docs/seo/S2_PRERENDER.md	
21. SEO S3 — Management Dashboard	103
docs/seo/S3_SEO_DASHBOARD.md	
22. SEO S4 — Sprach- und hreflang-Strategie	104
docs/seo/S4_LANGUAGE_AND_HREFLANG_STRATEGY.md	
23. Search Console MCP — Runbook (D5)	106
docs/seo/SEARCH_CONSOLE_MCP_RUNBOOK.md	
24. SEO Checklist & Technical Discovery Guide	107
docs/seo/SEO_CHECKLIST.md	
25. CAPITAL-AI SEO Management — Programm-Roadmap	109
docs/seo/SEO_MANAGEMENT_ROADMAP.md	
26. WP-S1 — SeoEngine Persistenz: Implementierungsplan & Status	112
docs/seo/WP_S1_PERSISTENCE_IMPLEMENTATION.md	
27. CAPITAL-AI — Video 01: SocialMedia API Schnittstellen in 5 Minuten anbinden	116
docs/social-media/VIDEO_01_SOCIAL_MEDIA_API_INTEGRATION_5MIN.md	

CAPITAL-AI — Enterprise Google Analytics Provisioner MCP

Quelle: docs/architecture/CAPITAL_AI_ENTERPRISE_GOOGLE_ANALYTICS_MCP_IMPLEMENTATION.md

CAPITAL-AI — Enterprise Google Analytics Provisioner MCP

Autonomous Implementation Specification for Claude Code

Document type: Enterprise Architecture + Autonomous Implementation Prompt

Target system: CAPITAL-AI / SvenKulesa/Finance

Target branch: current `main` at execution time

Evidence baseline used for this specification: 9ec92f66b1171dcec57bf7bb-ca9961833c70597e

Platform version observed: 0.6.0

Date: 2026-08-03

Primary executor: Claude Code / Claude Pro Code

Architecture class: Enterprise FinTech / Governance-Controlled MCP Integration

Status: IMPLEMENTATION SPECIFICATION — execution requires repository preflight and approval gates described below

0. EXECUTION DIRECTIVE FOR CLAUDE CODE

You are acting as the **Senior Enterprise Platform Architect, MCP Engineer, Google Analytics/Tag Manager Integration Engineer, IAM Engineer, Security Engineer, Privacy Engineer, Test Engineer and Documentary Engineer** for CAPITAL-AI.

Your task is to implement a production-grade **Google Analytics Provisioner MCP** inside the existing CAPITAL-AI architecture.

The implementation must:

1. inspect the current repository before changing anything;
2. adopt the existing architecture rather than building a parallel system;
3. preserve the existing IAM, TOTP step-up, EventMesh, Documentary, Traceability, Release and Compliance conventions;
4. use the Google Analytics Admin API for configuration writes;
5. use the Google Tag Manager API for tag/container/workspace/version operations;
6. use the official Google Analytics MCP and/or Google Analytics Data API for read-only post-change verification;
7. use Google OAuth 2.0 with least privilege, offline access only where necessary, secure refresh-token storage and explicit scope escalation;

8. maintain CookieHub as the consent source of truth unless an explicitly accepted ADR decides otherwise;
9. migrate from the current direct `gtag.js` integration to a controlled GTM-based architecture only after preview, consent verification and owner approval;
10. preserve CAPITAL-AI's existing **zero-Google-data-before-consent** privacy posture by using **Basic Consent Mode v2**, not Advanced Consent Mode, unless a later explicit legal/architecture decision changes that posture;
11. create all required code, manifests, tests, ADRs, runbooks, traceability updates and production handoff evidence;
12. never expose OAuth tokens, client secrets, refresh tokens, service credentials or sensitive analytics payloads to browser bundles, logs, MCP responses or documentation;
13. never create duplicate GA4 properties, data streams, GTM containers, tags, custom dimensions or environments if equivalent resources already exist;
14. default all external mutation tools to `dryRun=true`;
15. require an explicit approval artifact plus CAPITAL-AI owner/TOTP step-up for publish, destructive operations and production cutover;
16. fail closed whenever authorization, consent, resource identity, expected fingerprints, configuration state or verification evidence is ambiguous.

Do not merely produce a proposal. Implement the architecture in code and documentation, subject to the mandatory stop conditions and approval gates in this document.

1. CURRENT CAPITAL-AI BASELINE — DO NOT ASSUME, REVERIFY

Before implementation, inspect the current `main` branch and update this baseline if it has changed.

The evidence baseline used to write this specification currently shows:

- application name: `capital-ai`;
- version: `0.6.0`;
- runtime: Node.js `>=22`;
- frontend: React 19 + Vite;
- backend: Express;
- TypeScript at the root currently approximately `5.8.x`;
- current GA4 integration exists in `index.html`;
- current CookieHub integration exists in `index.html`;
- current GA4 loading is explicitly blocked until CookieHub `analytics` consent is granted;
- `VITE_GA_MEASUREMENT_ID` exists in `render.yaml`;
- current setup documentation exists in:

- `docs/runbooks/GOOGLE_ANALYTICS_SETUP.md` ;
- EventMesh exists as a versioned platform component;
- Traceability exists as a cross-cutting platform component;
- Documentary/Governance exists;
- PlatformDirector currently exposes a decision contract but is not to be falsely treated as a fully implemented runtime decision engine;
- current repository governance requires ADRs for architecture-changing decisions;
- production configuration is hosted on Render;
- Supabase is the database/auth platform;
- existing IAM and owner TOTP step-up controls must be reused for privileged analytics operations.

Critical current behavior

At the evidence baseline, `index.html` :

- loads CookieHub early;
- conditionally injects `https://www.googletagmanager.com/gtag/js` ;
- uses `window.cookiehub.hasConsented("analytics")` ;
- sets `ga-disable-<MEASUREMENT_ID>` when consent is absent;
- does not load GA4 without both a configured measurement ID and user analytics consent.

This behavior is a **privacy invariant** until the new implementation proves an equal or stricter result.

2. WHY THIS CHANGE REQUIRES A NEW ADR

The current runbook intentionally states that Google Consent Mode v2 is not used.

The target architecture changes the following architectural decisions:

- moves tag lifecycle management from direct `gtag.js` injection toward GTM-managed configuration;
- introduces an AI-callable MCP control plane;
- introduces Google OAuth write credentials;
- introduces controlled external configuration mutation;
- introduces automated drift detection and post-deploy verification;
- introduces a split read/write trust model;
- introduces Basic Consent Mode v2 while preserving the existing no-pre-consent-data posture.

Therefore Claude MUST:

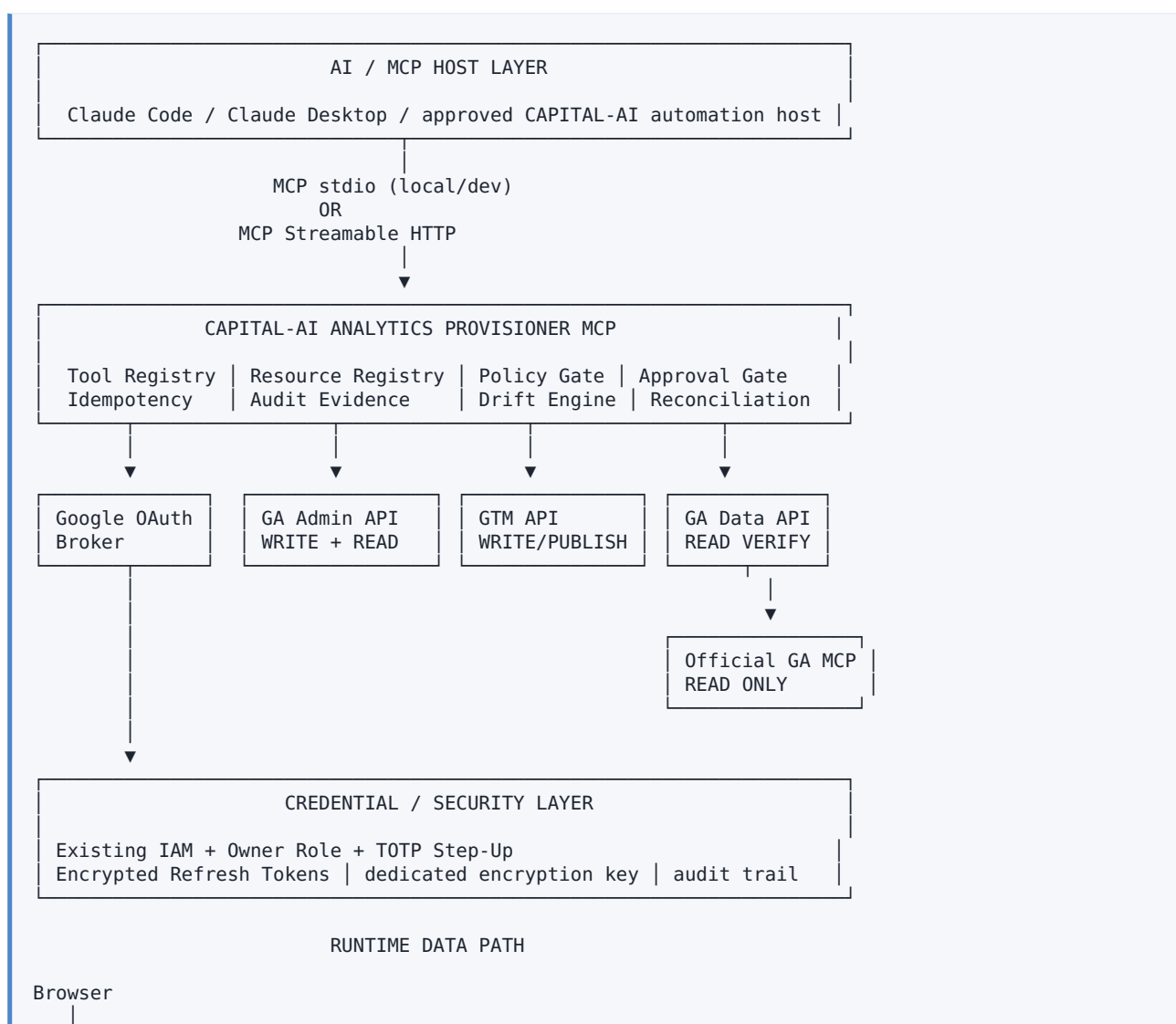
1. determine the next free ADR number at execution time;
2. create a new ADR;
3. reference the previous Google Analytics runbook and any affected security/privacy ADRs;
4. document the migration, rollback path, credential model and approval model;
5. set implementation status according to actual completed evidence;
6. never mark the ADR resolved until code, integration tests and production evidence are complete.

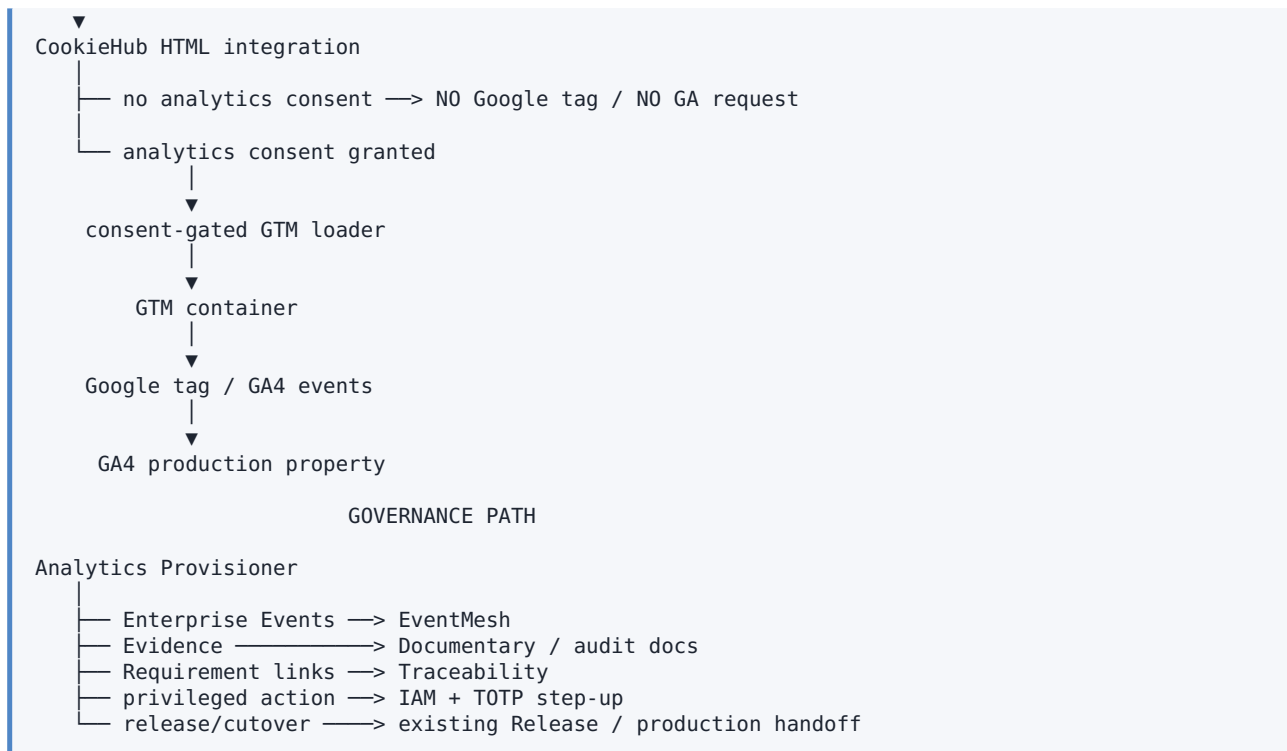
Suggested title:

ADR-XXXX-enterprise-google-analytics-provisioner-mcp.md

Do not hard-code ADR-0035 if another ADR has already consumed that number.

3. TARGET ARCHITECTURE





4. FUNDAMENTAL SEPARATION OF CONTROL PLANE AND DATA PLANE

4.1 Control plane

The MCP server is a **configuration control plane**.

It may:

- discover current GA/GTM state;
- create reconciliation plans;
- propose changes;
- apply approved GA Admin API changes;
- prepare GTM workspaces;
- create/modify tags and triggers;
- create GTM container versions;
- publish only after approval;
- verify resulting configuration and telemetry;
- produce drift and compliance reports.

It must never become a general unrestricted Google API proxy.

4.2 Data plane

The browser analytics runtime is the **data plane**.

The browser must never receive:

- Google OAuth client secret;
- OAuth refresh token;
- Google Admin API credentials;
- GTM API credentials;
- Supabase service/secret key;
- MCP administrative bearer credentials.

The browser may receive only public configuration such as:

- a GA Measurement ID if still temporarily needed;
 - a GTM public container ID;
 - CookieHub public domain identifier.
-

5. MCP PROTOCOL IMPLEMENTATION

5.1 Transport strategy

Support two modes:

Local development / Claude Code

Prefer **stdio**.

Advantages:

- no public network exposure;
- simplest trust boundary;
- Claude Code can spawn the process locally;
- credential access remains server-side.

Remote production/staging

Use **Streamable HTTP**.

Do not implement legacy HTTP+SSE as the primary transport.

Mandatory remote protections:

- HTTPS only;
- strict `Origin` validation;
- strict `Host` validation;
- existing CAPITAL-AI CORS policy;
- authenticated MCP calls;
- owner/admin authorization;

- no wildcard origins;
- rate limiting;
- request body limits;
- correlation IDs;
- structured security audit events;
- replay-resistant approval artifacts.

5.2 MCP SDK compatibility gate

At implementation time Claude MUST inspect the current official MCP TypeScript SDK.

The 2026 ecosystem is transitioning from the monolithic v1 SDK toward split v2 packages.

The root CAPITAL-AI project currently uses TypeScript ~5.8.x. Do not blindly force a root TypeScript major upgrade.

Perform a compatibility spike:

1. inspect current stable MCP SDK package requirements;
2. inspect CAPITAL-AI TypeScript/build compatibility;
3. if the current stable MCP v2 packages require TypeScript ≥ 6 or otherwise conflict with the root project: - isolate the MCP server as a self-contained package under: `tools/mcp/analytics-provisioner/` - give it its own `package.json`, lockfile strategy and `tsconfig.json`; - keep root application TypeScript unchanged unless a separate ADR approves a platform-wide upgrade;
4. if the current stable SDK works cleanly inside the root toolchain, integration inside `src/platform/AnalyticsProvisioner/` is permitted.

Do not depend on beta/preview packages in production without explicitly documenting the exception.

5.3 Recommended MCP server identity

```
name: capital-ai-analytics-provisioner
version: 1.0.0
```

6. REQUIRED MCP TOOL CATALOG

All tools must use validated schemas and return structured results.

Every mutating tool must support:

```
{
  dryRun: boolean;           // default true
  correlationId?: string;
  expectedStateHash?: string;
```

```
approvalId?: string;  
}
```

Every mutating result must include:

```
{  
  changed: boolean;  
  dryRun: boolean;  
  beforeHash: string;  
  afterHash?: string;  
  evidenceId: string;  
  warnings: string[];  
}
```

6.1 Discovery / read-only

`analytics_discover_accounts`

Discover accessible GA accounts.

`analytics_discover_properties`

Discover existing GA4 properties.

`analytics_get_property_state`

Read: - display name; - time zone; - currency; - data retention; - data streams; - enhanced measurement state where supported; - data-redaction settings where supported; - custom dimensions; - custom metrics; - key events; - Google product links; - change history if available.

`analytics_get_data_stream_state`

Read web stream details and Measurement ID.

`gtm_discover_accounts`

Read accessible GTM accounts.

`gtm_discover_containers`

Read GTM containers and public container IDs.

`gtm_get_live_state`

Read current live version, tags, triggers, variables and fingerprints.

`analytics_read_realtime`

Run a constrained GA Data API realtime report.

`analytics_read_report`

Run approved read-only reports.

6.2 Reconciliation

`analytics_build_reconciliation_plan`

Input:

- desired-state resource;
- detected current state;
- policy profile.

Output:

- no-op / create / patch actions;
- risk classification;
- required scopes;
- approval requirements;
- rollback strategy;
- expected final state hash.

This tool MUST NOT mutate anything.

`analytics_validate_reconciliation_plan`

Reject plans that:

- create duplicates;
- weaken consent;
- enable Google Signals without explicit approval;
- enable advertising personalization without explicit approval;
- introduce PII or financial-sensitive analytics fields;
- attempt a destructive delete;
- broaden OAuth scopes unnecessarily;
- publish GTM without a preview and approval.

6.3 GA Admin API writes

`analytics_ensure_property`

Idempotently adopt or create the intended property.

Default behavior: - discover and adopt an existing matching CAPITAL-AI property; - never create another property if a valid existing property is found.

`analytics_ensure_web_stream`

Idempotently adopt or create the production web stream for:

`https://capital-ai.online`

analytics_apply_property_settings

Manage approved settings such as: - timezone; - currency; - retention; - privacy-preserving configuration.

analytics_ensure_custom_dimensions

Only create dimensions present in the repository allowlist.

analytics_ensure_custom_metrics

Same policy as custom dimensions.

analytics_ensure_key_events

Only approved non-sensitive key events.

analytics_update_data_retention

Default target: minimum retention suitable for the use case, currently 2 months unless the current Google UI/API semantics have changed.

analytics_update_data_redaction

Where supported, enable protective redaction rules.

6.4 GTM writes

gtm_ensure_workspace

Create an isolated workspace:

CAPITAL-AI-AI-Provisioning-<timestamp-or-correlation-id>

gtm_reconcile_google_tag

Create or update the Google tag / GA4 tag configuration.

gtm_reconcile_triggers

Create only approved triggers.

gtm_reconcile_variables

Create only approved variables.

gtm_reconcile_consent_requirements

Ensure the Google tag cannot fire contrary to the approved CookieHub/Basic Consent Mode policy.

gtm_preview_workspace

Use GTM quick preview/status capability where available. Must run before container version creation.

gtm_create_container_version

Requires: - clean workspace status; - no compiler errors; - approved plan hash.

gtm_publish_container_version**HIGH-RISK TOOL**

Mandatory: - `dryRun=false`; - owner IAM role; - fresh TOTP step-up; - approval ID bound to plan hash and container version; - matching expected GTM fingerprint; - successful pre-view; - current production consent gate test; - rollback version recorded.

No automatic fallback publication.

6.5 Verification**analytics_verify_realtime**

Confirm expected test events after consent.

analytics_verify_no_preconsent_requests

Verify that, before analytics consent, there is: - no request to `google-analytics.com`; - no GA measurement request; - no Google tag request if CAPITAL-AI's strict zero-Google-request privacy policy is retained.

If GTM itself must be loaded from a Google domain before consent, STOP and classify this as a privacy-regression proposal. Do not silently accept it.

analytics_verify_postconsent_requests

Confirm expected requests only after consent.

analytics_verify_consent_revocation

After revocation: - new analytics events must stop; - analytics storage must be denied; - no unauthorized residual tag firing.

analytics_detect_drift

Compare actual GA/GTM state against repository desired state.

Default behavior: - report only; - do not auto-fix production drift.

7. GOOGLE OAUTH 2.0 ARCHITECTURE

There are TWO separate authorization concerns:

1. **MCP caller → CAPITAL-AI MCP server**
2. **CAPITAL-AI MCP server → Google APIs**

Do not mix these credentials.

8. MCP CALLER AUTHORIZATION

For local stdio mode: - OS/process trust boundary; - no network listener; - never print protocol-invalid data to stdout.

For remote Streamable HTTP mode: - reuse existing CAPITAL-AI IAM; - authenticated Supabase session/bearer identity; - owner/admin role for mutation; - owner role + fresh TOTP step-up for publish/destructive/high-risk changes; - map each MCP tool to an internal authorization permission.

Suggested permissions:

```
analytics.read
analytics.plan
analytics.configure
analytics.gtm.edit
analytics.gtm.version
analytics.gtm.publish
analytics.credentials.manage
analytics.rollback
analytics.audit.read
```

Never authorize based on: - email allowlists; - frontend role state; - editable user metadata; - MCP self-reported client identity.

9. GOOGLE API OAUTH CREDENTIAL MODEL

9.1 Preferred production flow

Use Google OAuth 2.0 **web-server authorization code flow**.

Requirements:

- authorization code flow;
- exact registered redirect URI;
- cryptographically random `state`;
- server-side callback;
- `access_type=offline` only for profiles that require autonomous operation;
- incremental authorization;
- secure refresh token handling;
- token revocation support;
- refresh-token failure/re-auth flow;
- no token in URL query logs;
- no token in browser storage.

9.2 Credential profiles

Implement logical credential profiles.

Profile A — READ_ONLY

Scopes:

```
https://www.googleapis.com/auth/analytics.readonly  
https://www.googleapis.com/auth/tagmanager.readonly
```

Used for: - discovery; - reconciliation; - drift checks; - verification.

Profile B — CONFIGURATOR

Scopes:

```
https://www.googleapis.com/auth/analytics.edit  
https://www.googleapis.com/auth/tagmanager.edit.containers  
https://www.googleapis.com/auth/tagmanager.edit.containerversions
```

Used for: - GA property/stream settings; - GTM workspace/tag/trigger/variable configuration; - container version creation.

Profile C — PUBLISHER

Additional scope:

```
https://www.googleapis.com/auth/tagmanager.publish
```

Used only for approved GTM publication.

Do NOT request by default:

```
https://www.googleapis.com/auth/tagmanager.delete.containers  
https://www.googleapis.com/auth/tagmanager.manage.users  
https://www.googleapis.com/auth/tagmanager.manage.accounts  
https://www.googleapis.com/auth/analytics.manage.users
```

unless a later explicit requirement and ADR justifies them.

9.3 Optional Analytics-only service account

Google Analytics Admin/Data APIs can support a service account when that service account is explicitly granted access to the Analytics property/account.

If Claude determines a service account materially reduces operational OAuth risk for read-only verification, it may propose:

- service account for read-only GA verification;
- user OAuth for GTM writes/publish.

Do not assume GTM service-account access without verifying current official support and account permissions.

10. OAUTH TOKEN STORAGE

Never store refresh tokens: - in source control; - in `.env.example`; - in plaintext database columns; - in browser localStorage/sessionStorage; - in logs; - in MCP resources; - in error messages.

10.1 Dedicated encryption key

Create a dedicated key:

```
GOOGLE_OAUTH_TOKEN_ENCRYPTION_KEY
```

Do not reuse: - TOTP encryption key; - Stripe secrets; - Supabase secrets; - session secrets.

Use authenticated encryption, e.g. AES-256-GCM, with: - random nonce/IV per encryption; - auth tag; - versioned ciphertext envelope; - key-version field; - rotation strategy.

10.2 Persistence

Preferred within the existing CAPITAL-AI stack:

- encrypted token records in a non-exposed/private Supabase schema;
- service/backend-only access;
- no browser Data API exposure;
- explicit grants;
- security review;
- migration committed to repository.

Suggested logical record:

```
interface GoogleOAuthCredentialRecord {
  id: string;
  profile: "READ_ONLY" | "CONFIGURATOR" | "PUBLISHER";
  googleSubject?: string;
  scopes: string[];
  encryptedRefreshToken: string;
  encryptionVersion: number;
  createdAt: string;
  updatedAt: string;
  lastRefreshAt?: string;
  revokedAt?: string;
  lastValidatedAt?: string;
}
```

If the repository does not currently expose a safe private schema pattern, Claude must: 1. inspect Supabase architecture; 2. create a repository migration; 3. run advisors/tests; 4. require explicit production database approval before applying live DDL.

11. GOOGLE ANALYTICS ADMIN API

Use the Google Analytics Admin API as the authoritative write API for GA configuration.

At minimum support idempotent management of:

- accounts discovery;
- properties;
- web data streams;
- property settings;
- data retention;
- custom dimensions;
- custom metrics;
- key events;
- data redaction where supported;
- enhanced measurement where supported;
- change-history inspection where supported.

Do not use deprecated conversion-event APIs where a current key-event API exists.

Prefer GA API beta/stable endpoints for production functionality. Alpha endpoints must be isolated behind capability flags and require documentation.

12. GOOGLE ANALYTICS DATA API / OFFICIAL GOOGLE ANALYTICS MCP

The official Google Analytics MCP is **read-only**.

Treat this as a feature, not a limitation.

Use the read path for independent verification of: - property visibility; - realtime activity; - event presence; - page views; - approved metrics; - post-deploy telemetry.

The write path must remain in the CAPITAL-AI Provisioner through Admin API/GTM API.

Do not attempt to make the official Google Analytics MCP perform configuration mutations.

13. GOOGLE TAG MANAGER API

Use GTM API v2.

Required lifecycle:

```
discover
↓
get live version/fingerprint
↓
create isolated workspace
↓
apply tags/triggers/variables
↓
workspace status
↓
quick preview
↓
create container version
↓
owner approval + TOTP
↓
publish
↓
post-publish verification
↓
evidence
```

No direct blind mutation of a live GTM container.

13.1 Optimistic concurrency

Use GTM fingerprints where supported.

If expected fingerprint differs from current: - STOP; - classify as concurrent modification; - resync; - rebuild plan; - require renewed approval if the plan changes.

14. COOKIEHUB + CONSENT MODE V2

14.1 Source of truth

CookieHub remains the source of truth for user consent.

The project currently uses CookieHub directly in HTML.

Do not introduce a second consent system.

14.2 Target mode

Use **Google Consent Mode v2 — Basic implementation**.

Privacy invariant:

No analytics data is sent to Google before the visitor grants the relevant analytics consent.

Do NOT enable Advanced Consent Mode by default.

Advanced mode may send cookieless measurements before consent and therefore changes CAPITAL-AI's current privacy posture.

14.3 Consent signals

Where applicable, maintain v2 signals:

```
analytics_storage  
ad_storage  
ad_user_data  
ad_personalization
```

Default CAPITAL-AI policy:

```
analytics_storage = denied until analytics consent  
ad_storage = denied  
ad_user_data = denied  
ad_personalization = denied
```

CAPITAL-AI currently has no requirement in this specification to enable ads personalization.

14.4 CookieHub automation boundary

Do not invent a CookieHub management API.

At implementation time: - inspect the current CookieHub plan/docs; - if a documented API exists and the account has access, implement only documented operations; - otherwise generate a precise owner runbook for the dashboard step.

Never use browser scraping as an enterprise configuration API.

14.5 Migration pattern

Preferred privacy-preserving pattern:

1. CookieHub continues to load first in HTML.
2. CookieHub remains responsible for obtaining consent.
3. GTM is not allowed to produce Google analytics traffic before analytics consent.
4. after analytics consent, load/activate the GTM data plane;
5. GTM manages the Google tag;
6. Consent Mode v2 Basic communicates the consent state without Advanced pre-consent measurement.

If the chosen technical GTM installation causes a request to Google's tag infrastructure before user consent and this conflicts with the documented CAPITAL-AI privacy rule: - STOP; - do not publish; - record the conflict in the ADR; - retain the current direct consent-gated implementation until an approved alternative exists.

15. MIGRATION FROM DIRECT GTAG TO GTM

Never run both production tracking paths simultaneously.

Phase A — discovery only

- read current GA property;
- identify existing web stream;
- identify existing GTM account/container;
- read current CookieHub behavior;
- produce desired-state diff.

No browser code change.

Phase B — GTM shadow configuration

- create isolated GTM workspace;
- configure Google tag;
- configure approved events;
- preview;
- no publication.

Phase C — automated privacy tests

Test current and proposed behavior.

Required invariant:

```
PRE-CONSENT:  
google analytics measurement requests == 0
```

Phase D — approval

Generate immutable evidence:

```
{  
  planHash,  
  currentGaStateHash,  
  currentGtmStateHash,  
  proposedContainerVersionId,  
  consentTestEvidenceId,  
  rollbackVersionId,  
  createdAt  
}
```

Require owner approval + TOTP.

Phase E — publish and application cutover

- publish approved GTM version;
- replace direct GA loader with approved consent-gated GTM loader;
- ensure only one measurement path remains;
- deploy;

- run post-deploy checks.

Phase F — deprecate old variable

After one successful release and rollback window:

- deprecate `VITE_GA_MEASUREMENT_ID` if no longer required by runtime;
- introduce `VITE_GTM_CONTAINER_ID` if required;
- update `.env.example`;
- update `render.yaml` placeholders;
- update runbooks.

Never delete rollback support in the same change that first introduces the new path.

16. ANALYTICS DATA CLASSIFICATION — FINTECH REQUIREMENT

CAPITAL-AI is a FinTech application.

Google Analytics must NOT become a sink for sensitive financial or identity data.

16.1 Prohibited parameters

Do not send:

- email address;
- full name;
- phone number;
- postal address;
- Supabase user UUID;
- Stripe customer/subscription IDs;
- OAuth subject IDs;
- access tokens;
- session tokens;
- IAM role identifiers tied to a person;
- portfolio holdings;
- transaction details;
- account balances;
- bank/payment details;
- raw financial-screening inputs;
- user-entered prompts;
- asset watchlists tied to identity;

- exact user financial preferences;
- passwords, MFA/TOTP data;
- IP-derived custom identifiers;
- any value prohibited by Google Analytics policies.

Do not send hashed email as a workaround.

16.2 Default approved analytics vocabulary

Start with coarse product analytics only:

```
page_view
navigation
feature_opened
feature_completed
feature_failed
upgrade_prompt_viewed
subscription_page_viewed
consent_settings_opened
```

For feature names use an allowlist such as:

```
screening
backtest
monte_carlo
warren_buffett_value_check
security_compliance
profile
billing
```

Do not attach: - searched symbol; - portfolio content; - free-text prompt; - personal subscription identifiers.

16.3 URL sanitation

Before any page location reaches analytics: - strip query parameters by default; - strip fragments; - normalize dynamic IDs; - block routes containing tokens/callback secrets; - never record OAuth callback query strings; - never record password-reset tokens.

17. TYPED CLIENT ANALYTICS CONTRACT

Create a browser-side analytics façade.

Suggested path:

```
src/services/analytics/
  analyticsEvents.ts
  analyticsPolicy.ts
  analyticsDataLayer.ts
  analyticsRouteSanitizer.ts
  index.ts
```

Example conceptual contract:

```

type AnalyticsEventName =
  | "navigation"
  | "feature_opened"
  | "feature_completed"
  | "feature_failed"
  | "upgrade_prompt_viewed"
  | "subscription_page_viewed"
  | "consent_settings_opened";

type AnalyticsFeature =
  | "screening"
  | "backtest"
  | "monte_carlo"
  | "warren_buffett_value_check"
  | "security_compliance"
  | "profile"
  | "billing";

interface AnalyticsEvent {
  name: AnalyticsEventName;
  feature?: AnalyticsFeature;
  route?: string;
  outcome?: "success" | "failure" | "cancelled";
}

```

The façade must: - validate event names; - validate fields; - strip unknown fields; - reject PII-like field names; - push only sanitized events to `dataLayer`; - do nothing when consent is not granted.

18. DO NOT MIRROR EVENTMESH PAYLOADS INTO GA

CAPITAL-AI EventMesh contains operational and domain events.

Never forward arbitrary EventMesh payloads to Google Analytics.

Create an explicit adapter if needed:

```

Enterprise Event
  ↓
AnalyticsExportPolicy
  ↓
allowlisted coarse event
  ↓
dataLayer

```

Default: **no EventMesh → GA export.**

Any mapping must: - be explicit; - be documented; - be tested for sensitive-field exclusion.

19. DESIRED-STATE CONFIGURATION

Create a repository-controlled desired-state document.

Suggested location:

```
config/analytics/analytics-desired-state.yaml
```


Example:

```

schemaVersion: "1.0.0"

application:
  name: CAPITAL-AI
  productionUrl: https://capital-ai.online

privacy:
  consentProvider: cookiehub
  consentMode: basic-v2
  zeroGoogleAnalyticsDataBeforeConsent: true
  adsPersonalization: false
  googleSignals: false
  urlQueryCollection: false

ga4:
  adoptExistingProperty: true
  timezone: Europe/Berlin
  currency: EUR
  dataRetentionMonths: 2

gtm:
  adoptExistingContainer: true
  publishRequiresOwnerStepUp: true
  automaticPublish: false

events:
  allowed:
    - navigation
    - feature_opened
    - feature_completed
    - feature_failed
    - upgrade_prompt_viewed
    - subscription_page_viewed
    - consent_settings_opened

prohibitedParameterPatterns:
    - email
    - phone
    - address
    - password
    - token
    - secret
    - user_id
    - customer_id
    - subscription_id
    - portfolio
    - balance

```

This file is the target for reconciliation, not a container for real secrets or external resource tokens.

20. RECOMMENDED PLATFORM COMPONENT STRUCTURE

Claude must first inspect existing platform naming and manifest conventions.

Preferred structure if compatible:

```

src/platform/AnalyticsProvisioner/
├── README.md
├── CHANGELOG.md
├── manifest.json
├── component.yaml
├── Contracts/

```

```

├── AnalyticsDesiredState.ts
├── AnalyticsPlan.ts
├── AnalyticsEvidence.ts
├── AnalyticsApproval.ts
├── AnalyticsDrift.ts
├── Core/
│   ├── AnalyticsProvisioner.ts
│   ├── ReconciliationEngine.ts
│   ├── DesiredStateHasher.ts
│   └── IdempotencyGuard.ts
├── OAuth/
│   ├── GoogleOAuthBroker.ts
│   ├── GoogleScopePolicy.ts
│   ├── GoogleCredentialVault.ts
│   └── GoogleTokenCrypto.ts
├── Adapters/
│   ├── GoogleAnalyticsAdminAdapter.ts
│   ├── GoogleAnalyticsDataAdapter.ts
│   ├── GoogleTagManagerAdapter.ts
│   └── CookieHubConsentAdapter.ts
├── Policies/
│   ├── AnalyticsMutationPolicy.ts
│   ├── AnalyticsPrivacyPolicy.ts
│   ├── AnalyticsEventExportPolicy.ts
│   └── AnalyticsPublishPolicy.ts
├── MCP/
│   ├── createAnalyticsMcpServer.ts
│   ├── registerAnalyticsTools.ts
│   ├── registerAnalyticsResources.ts
│   └── schemas.ts
├── Services/
│   ├── AnalyticsVerificationService.ts
│   ├── AnalyticsDriftService.ts
│   ├── GtmReleaseService.ts
│   └── AnalyticsEvidenceService.ts
├── Events/
│   └── AnalyticsProvisioningEvents.ts
├── Tests/
│   ├── reconciliation.test.ts
│   ├── privacyPolicy.test.ts
│   ├── oauthScopePolicy.test.ts
│   ├── mcpTools.test.ts
│   └── gtmReleasePolicy.test.ts

```

If MCP SDK compatibility requires an isolated package:

```
tools/mcp/analytics-provisioner/
```

must wrap/reuse the platform contracts rather than duplicating domain rules.

21. SERVER ROUTING

Do not expand `server.ts` with a large implementation.

Add focused routers/services.

Suggested:

```

server/analytics/
  googleOAuthRouter.ts
  analyticsMcpRouter.ts
  analyticsApprovalRouter.ts

```

`server.ts` should only mount the router.

Possible routes:

```
GET /api/integrations/google/oauth/start
GET /api/integrations/google/oauth/callback
POST /api/integrations/google/oauth/revoke

POST /api/analytics/approvals
GET /api/analytics/approvals/:id

ALL /mcp/analytics
```

OAuth callback must: - validate state; - use exact redirect URI; - exchange code server-side; - store refresh token encrypted; - redirect to a safe application route without tokens.

22. ENVIRONMENT VARIABLES

Add placeholders only.

Never commit actual values.

Suggested:

```
GOOGLE_OAUTH_CLIENT_ID=
GOOGLE_OAUTH_CLIENT_SECRET=
GOOGLE_OAUTH_REDIRECT_URI=

GOOGLE_OAUTH_TOKEN_ENCRYPTION_KEY=

GOOGLE_ANALYTICS_ACCOUNT_ID=
GOOGLE_ANALYTICS_PROPERTY_ID=
GOOGLE_ANALYTICS_WEB_STREAM_ID=

GOOGLE_GTM_ACCOUNT_ID=
GOOGLE_GTM_CONTAINER_ID=

VITE_GTM_CONTAINER_ID=

ANALYTICS_MCP_ENABLED=false
ANALYTICS_MCP_REMOTE_ENABLED=false
```

Existing during migration:

```
VITE_GA_MEASUREMENT_ID=
```

Do not remove the existing variable until cutover evidence and rollback requirements are satisfied.

Render values remain external secrets/config and must not be committed.

23. GOOGLE CLOUD BOOTSTRAP — HUMAN-IN-THE-LOOP

Some steps may require the repository owner to use the Google Cloud / Google Analytics UI.

Claude must distinguish between:

- code/API-automatable actions;
- OAuth consent actions requiring a human;
- Google-account Terms of Service acceptance;
- account/property access grants;
- production publish approval.

Required one-time bootstrap may include:

1. choose/create Google Cloud project;
2. enable: - Google Analytics Admin API; - Google Analytics Data API; - Google Tag Manager API;
3. configure Google Auth Platform/OAuth consent screen;
4. create OAuth web application credentials;
5. register exact redirect URIs;
6. authorize the CAPITAL-AI owner account;
7. grant the account/service identity appropriate Analytics/GTM access.

Claude must generate an exact runbook for any step it cannot legitimately automate.

Do not report a UI-only step as completed unless evidence exists.

24. GOOGLE OAUTH REDIRECT URI

Production example:

```
https://capital-ai.online/api/integrations/google/oauth/callback
```

Development redirect URI must be explicitly configured.

Do not use wildcard redirect URIs.

Do not dynamically derive a redirect URI from untrusted request headers.

25. APPROVAL ARTIFACT

Create a first-class approval contract.

Suggested:

```
interface AnalyticsApproval {
  id: string;
  actorUserId: string;
  action:
    | "GA_CONFIG_WRITE"
    | "GTM_VERSION_CREATE"
    | "GTM_PUBLISH"
    | "ROLLBACK";
  planHash: string;
  targetResource: string;
  expectedFingerprint?: string;
  approvedAt: string;
  expiresAt: string;
  stepUpEvidenceId?: string;
  consumedAt?: string;
}
```

Rules:

- short TTL;
- single use;
- bound to actor;
- bound to plan hash;
- bound to target;
- cannot be replayed for a different container version;
- publish requires step-up evidence;
- log consumption.

26. AUDIT / EVIDENCE MODEL

Every execution creates evidence.

Example:

```
interface AnalyticsProvisioningEvidence {
  evidenceId: string;
  correlationId: string;
  operation: string;
  actorUserId?: string;
  target: string;
  dryRun: boolean;
  beforeHash?: string;
  afterHash?: string;
  googleChangeResource?: string;
  gtmWorkspaceId?: string;
  gtmVersionId?: string;
  approvalId?: string;
  result: "NOOP" | "SUCCESS" | "FAILED" | "BLOCKED";
  reasons: string[];
  createdAt: string;
}
```

Do not include: - raw tokens; - client secrets; - sensitive response payloads.

27. ENTERPRISE EVENTMESH INTEGRATION

Do not directly import EventMesh implementation if current contracts prohibit it.

Follow the existing public interfaces and component rules.

Add versioned enterprise events, after checking naming rules.

Suggested semantic event set:

```
AnalyticsProvisioningRequested
AnalyticsProvisioningPlanCreated
AnalyticsApprovalRequired
AnalyticsConfigurationApplied
AnalyticsGtmVersionCreated
AnalyticsGtmPublished
AnalyticsVerificationPassed
AnalyticsVerificationFailed
AnalyticsDriftDetected
AnalyticsRollbackRequested
AnalyticsRollbackCompleted
GoogleOAuthCredentialAuthorized
GoogleOAuthCredentialRevoked
```

Before introducing these names: - inspect EventMesh event catalog; - avoid duplicates; - conform to ESS-0001-CONTRACTS and EventMesh naming/version rules; - update producer/consumer registry; - add contract tests.

28. DOCUMENTARY INTEGRATION

The Documentary layer must record:

- architecture decision;
- implementation state;
- external dependency inventory;
- scopes;
- credentials ownership;
- consent model;
- test evidence;
- runbooks;
- production handoff;
- residual risks.

Do not generate documentation that claims live configuration is applied if only repository code exists.

29. TRACEABILITY

Update/build the traceability chain:

```
Requirement
↓
ADR
↓
ESS / contracts
↓
Component
↓
Code
↓
Tests
↓
External configuration evidence
↓
Production verification evidence
```

Run the repository's traceability build command after implementation.

Any new component manifest must point to: - ADR; - contracts; - tests; - documentation; - events.

30. PLATFORM DIRECTOR BOUNDARY

At the evidence baseline, PlatformDirector is marked `development` and contains a decision contract but not a complete runtime decision engine.

Therefore:

- do not fabricate a runtime PlatformDirector dependency;
- integrate via existing contract/event boundaries if real APIs exist;
- record future PlatformDirector policy ownership in documentation;
- do not claim runtime enforcement by PlatformDirector unless implemented and tested.

The Analytics Provisioner must have its own fail-closed policy enforcement today.

31. GITHUB AUTOMATION

Claude Code is expected to implement changes through normal Git workflow.

Required workflow:

1. start from current `main`;
2. verify clean working tree;
3. create branch: `agent/enterprise-analytics-provisioner-mcp`;
4. implement in small coherent commits;
5. run tests/lint/build;

6. run architecture/traceability checks;
7. prepare a PR;
8. include exact external production steps that remain;
9. do not auto-merge;
10. do not delete old rollback code before production acceptance.

The PR description must explicitly separate:

- repository changes;
 - Google external changes;
 - CookieHub external changes;
 - Render external changes;
 - Supabase migration changes;
 - steps executed;
 - steps pending approval.
-

32. GITHUB / CI SECURITY

Do not put Google user refresh tokens into GitHub Actions secrets merely for convenience.

If automated CI read-only validation against Google APIs is later required, prefer:

- short-lived identity;
- Workload Identity Federation where supported;
- separate read-only service identity;
- no publisher scope in CI.

GTM publication must not be triggered by arbitrary pull-request code.

33. SUPABASE PRODUCTION BOUNDARY

If OAuth credential persistence requires a new database table/schema:

- create migration through existing Supabase migration conventions;
- private/non-exposed schema preferred;
- no public REST exposure;
- explicit privilege grants;
- run security advisors;
- tests;
- document rollback;
- do not use user-editable metadata for authorization.

Do not apply production DDL merely because the migration exists.

Production DDL requires the project's controlled production-handoff process.

34. RENDER PRODUCTION BOUNDARY

`render.yaml` may contain placeholders for required variables.

Actual values: - must be configured in Render; - must never be committed; - should be described in a production handoff checklist.

After changing any Vite `VITE_*` variable: - a rebuild/redeploy is required because those values are build-time injected.

Do not claim a runtime configuration change is effective before deployment evidence.

35. CSP / CORS / SECURITY HEADERS

Inspect the current CSP before adding GTM.

Do not loosen to broad wildcards.

Only add exact required domains to the relevant directives.

Potential domains may include, depending on actual implementation:

```
https://www.googletagmanager.com
https://www.google-analytics.com
https://*.google-analytics.com
https://cdn.cookiehub.eu
```

Do not add a domain unless network evidence proves it is required.

CORS: - MCP endpoint must not accept arbitrary origins; - OAuth callback is server-side; - Google API calls occur backend-to-backend.

36. SSR / SPA TRACKING RULES

CAPITAL-AI is a React/Vite SPA.

Implement: - initial page view after consent; - virtual page views on SPA route changes; - sanitized route path; - no query-string leakage; - deduplication so initial navigation is not double counted.

Inspect the actual routing architecture first. Do not assume React Router is installed.

37. GTM CONFIGURATION POLICY

The AI may create only allowlisted objects.

Default allowlist:

- one Google tag / GA4 configuration;
- page/route tracking;
- approved custom events;
- CookieHub-compatible consent controls;
- no Ads tags;
- no remarketing;
- no Floodlight;
- no custom HTML that exfiltrates data;
- no arbitrary third-party pixels.

Any Custom HTML tag must be blocked by policy unless explicitly approved.

38. GOOGLE ANALYTICS PRIVACY SETTINGS

Default desired state:

- minimum practical event retention;
- Google Signals disabled unless explicitly approved;
- Ads personalization disabled;
- no Google Ads links unless explicitly approved;
- no user-provided data;
- no Measurement Protocol server-side events by default;
- no PII;
- no financial-sensitive custom dimensions.

If a current external configuration conflicts with these defaults: - report drift; - do not silently change until the plan is approved.

39. MEASUREMENT PROTOCOL

Do not enable by default.

If later required: - separate ADR; - separate secret; - explicit consent mapping; - server-side event policy; - duplicate-event controls; - transaction/event idempotency; - PII/financial-data review.

The presence of Admin API support for Measurement Protocol secrets is not permission to create one automatically.

40. DRIFT DETECTION

Desired state is version controlled.

Drift categories:

```
NONE
BENIGN
CONFIGURATION
PRIVACY
SECURITY
PUBLISH_STATE
UNKNOWN
```

Examples:

- measurement ID changed → CONFIGURATION;
- Google Signals enabled unexpectedly → PRIVACY;
- GTM Custom HTML tag added → SECURITY;
- live GTM version differs from repository evidence → PUBLISH_STATE.

Default response: - evidence report; - EventMesh event; - no automatic repair.

41. ROLLBACK

Before every GTM publish: - record current live version; - record version fingerprint; - record intended new version; - record rollback command/API target.

Rollback tool requires: - explicit action; - owner TOTP step-up; - audit event.

Rollback must restore: - previous GTM live version; - compatible runtime loader configuration if cutover involved app code.

Do not roll back OAuth or consent state blindly.

42. OBSERVABILITY

Add structured metrics/logs for the control plane:

```
analytics_mcp_tool_calls_total
analytics_mcp_tool_failures_total
analytics_google_api_requests_total
analytics_google_api_rate_limit_total
analytics_drift_detected_total
analytics_publish_attempts_total
```

```
analytics_publish_blocked_total  
analytics_verification_failures_total
```

Never label metrics with: - email; - token; - Google subject; - raw URL with query; - asset symbol tied to user behavior.

43. RATE LIMITING / RETRY

For Google APIs: - respect quota errors; - exponential backoff with jitter for retryable failures; - do not retry authorization failures endlessly; - do not retry non-idempotent mutation without idempotency/reconciliation guard; - surface actionable errors.

MCP tool calls: - enforce existing rate limiter for remote mode; - stricter limit on write/publish tools.

44. ERROR MODEL

Use stable error codes.

Suggested:

```
ANALYTICS_AUTH_REQUIRED  
ANALYTICS_INSUFFICIENT_SCOPE  
ANALYTICS_RESOURCE_AMBIGUOUS  
ANALYTICS_DUPLICATE_RESOURCE_RISK  
ANALYTICS_PLAN_STALE  
ANALYTICS_APPROVAL_REQUIRED  
ANALYTICS_APPROVAL_EXPIRED  
ANALYTICS_STEP_UP_REQUIRED  
ANALYTICS_GTM_CONFLICT  
ANALYTICS_GTM_COMPILER_ERROR  
ANALYTICS_CONSENT_REGRESSION  
ANALYTICS_PRIVACY_POLICY_VIOLATION  
ANALYTICS_VERIFICATION_FAILED  
ANALYTICS_DRIFT_DETECTED  
ANALYTICS_EXTERNAL_RATE_LIMIT
```

Return safe errors through MCP. Log sensitive internals only in sanitized server logs.

45. TEST STRATEGY

45.1 Unit tests

Required:

- desired-state hashing;
- reconciliation idempotency;
- duplicate prevention;

- scope policy;
- token encryption/decryption;
- token redaction;
- approval TTL/replay protection;
- publish policy;
- PII field blocker;
- route sanitizer;
- event allowlist;
- GTM fingerprint conflict;
- dry-run behavior.

45.2 Contract tests

Required:

- MCP tool schemas;
- EventMesh event contracts;
- platform manifest integrity;
- desired-state schema.

45.3 Integration tests

Use fake/stub adapters by default.

Real Google integration tests: - opt-in only; - separate non-production resource; - never publish production.

45.4 Browser/E2E privacy test

This is mandatory before production cutover.

Scenario A — fresh visitor, no consent: - open application; - do not accept analytics; - assert no GA measurement; - assert no unauthorized Google analytics tag request according to chosen strict policy.

Scenario B — analytics consent granted: - grant analytics; - assert approved GTM/GA resources load; - assert one initial page view; - navigate SPA; - assert sanitized virtual page view.

Scenario C — revoke consent: - revoke analytics; - assert subsequent events are blocked.

Scenario D — returning user: - stored consent respected; - no race condition causing lost or premature events.

If Playwright is not present: - evaluate adding it as a pinned dev dependency; - document the dependency and keep tests isolated.

46. BUILD / QUALITY GATES

At minimum run:

```
npm run lint
npm test
npm run build
npm run traceability:build
npm run predeploy:check
```

Also run any component-specific tests introduced.

If the MCP package is isolated, run its own:

```
npm ci
npm run lint
npm test
npm run build
```

Do not declare success if any mandatory gate fails.

47. SECURITY NEGATIVE TESTS

Test that:

- anonymous caller cannot use MCP write tools;
 - normal user cannot configure GA;
 - admin without required permission cannot publish;
 - owner without fresh TOTP cannot publish;
 - expired approval cannot publish;
 - approval for plan A cannot publish plan B;
 - refresh token cannot be retrieved via MCP resource;
 - logs do not contain OAuth tokens;
 - browser bundle does not contain Google client secret;
 - unknown event fields are discarded/rejected;
 - PII-looking fields are rejected;
 - GTM Custom HTML insertion is blocked by default.
-

48. DOCUMENTATION DELIVERABLES

Create or update:

```
docs/architecture/ENTERPRISE_GOOGLE_ANALYTICS_MCP_ARCHITECTURE.md
docs/runbooks/GOOGLE_ANALYTICS_SETUP.md
docs/runbooks/GOOGLE_ANALYTICS_MCP_PROVISIONING.md
docs/runbooks/GOOGLE_ANALYTICS_ROLLBACK.md
```

```
docs/security/GOOGLE_OAUTH_TOKEN_SECURITY.md
docs/compliance/GOOGLE_ANALYTICS_CONSENT_EVIDENCE.md
docs/adr/ADR-XXXX-enterprise-google-analytics-provisioner-mcp.md
```

Update: - ADR index; - component registry/manifest; - Documentary references; - Traceability matrix; - deployment/environment documentation; - security/compliance inventory.

49. README / OPERATOR RUNBOOK CONTENT

The operator runbook must include:

Connect Google

- required account;
- required APIs;
- redirect URI;
- requested scopes;
- authorization procedure;
- revocation procedure.

Audit

- run read-only discovery;
- compare desired vs actual;
- inspect drift report.

Prepare change

- build plan;
- inspect risk;
- create GTM workspace;
- preview.

Approve

- owner authentication;
- TOTP step-up;
- approval artifact.

Publish

- version creation;
- publication;
- correlation ID.

Verify

- consent test;
- realtime test;
- route event test;
- no-PII check.

Roll back

- restore prior GTM version;
- verify.

50. EXTERNAL CONFIGURATION EVIDENCE

Store non-secret evidence only.

Suggested:

```
docs/production/evidence/analytics/  
  PRECHECK-<date>.md  
  PROVISIONING-PLAN-<correlation-id>.md  
  GTM-PREVIEW-<correlation-id>.md  
  CONSENT-TEST-<correlation-id>.md  
  POSTCHECK-<date>.md
```

Never store: - OAuth authorization code; - access token; - refresh token; - client secret; - measurement protocol secret.

51. IMPLEMENTATION PHASES

PHASE 0 — PRE-FLIGHT

Claude must:

1. fetch current `main`;
2. identify current latest commit;
3. inspect open PRs;
4. inspect: - `package.json`; - lockfile; - `server.ts`; - IAM; - TOTP step-up; - EventMesh; - Traceability; - Documentary; - Security/Compliance; - Release; - current GA/CookieHub integration; - Render config;
5. determine next ADR number;
6. identify current GA Measurement ID without inventing it;
7. identify whether GTM already exists;
8. produce a short pre-flight evidence document.

STOP if the working tree or branch state is ambiguous.

PHASE 1 — ADR + DESIRED STATE

- create ADR;
- create desired-state YAML;
- create contracts;
- create component manifest;
- no external mutation.

PHASE 2 — READ-ONLY CONNECTIVITY

Implement: - OAuth broker; - READ_ONLY profile; - GA Admin read; - GA Data read; - GTM read; - MCP read tools.

Verify account/property/container discovery.

No writes.

PHASE 3 — RECONCILIATION ENGINE

Implement: - state normalization; - desired-state hashing; - diff; - policy; - approval requirements; - dry-run.

No writes.

PHASE 4 — GA CONFIGURATION WRITE PATH

Implement Admin API writes behind: - CONFIGURATOR credentials; - dry-run; - approval policy where required; - audit evidence.

Apply only after plan review.

PHASE 5 — GTM WORKSPACE WRITE PATH

Implement: - workspace; - tags; - triggers; - variables; - preview; - container version.

Do not publish.

PHASE 6 — CONSENT + FRONTEND MIGRATION

Implement: - typed analytics event façade; - privacy policy; - consent-gated GTM loader; - SPA page view tracking; - old direct gtag path retained only as rollback until cutover.

Ensure no double measurement.

PHASE 7 — PUBLISH GATE

Add: - approval artifact; - owner/TOTP requirement; - GTM publish tool; - rollback capture.

PHASE 8 — PRODUCTION CUTOVER

Only after owner approval: - publish GTM; - deploy code; - validate zero pre-consent data; - validate post-consent realtime events; - validate revocation; - collect evidence.

PHASE 9 — CLEANUP

After accepted production evidence: - remove obsolete direct gtag code; - deprecate obsolete env variable if truly unused; - update runbook status; - mark implementation complete only if all acceptance criteria pass.

52. STOP CONDITIONS

Claude MUST STOP before a production mutation if any of the following occurs:

- multiple plausible GA properties;
- multiple plausible GTM containers;
- missing Google account ownership;
- insufficient scopes;
- OAuth consent not completed;
- unexpected Google API resource;
- privacy policy conflict;
- pre-consent Google analytics traffic;
- GTM workspace/compiler error;
- stale fingerprint;
- missing rollback version;
- missing owner approval;
- missing TOTP step-up;
- failed build;
- failed tests;
- failed traceability;
- failed production verification;
- unreviewed destructive action;
- undocumented external change.

When stopped: - do not guess; - produce exact evidence and next required action.

53. DESTRUCTIVE ACTION POLICY

Default forbidden through MCP:

- delete GA account;
- delete GA property;
- delete data stream;
- delete GTM container;
- delete GTM account;
- manage Google users;
- transfer ownership;
- unlink Google services;
- purge analytics history.

If cleanup is genuinely necessary: - create separate plan; - require explicit owner approval;
- require step-up; - preserve rollback where possible.

54. NO-DEMO / NO-FAKE-DATA POLICY

Do not: - fabricate Analytics property IDs; - fabricate Measurement IDs; - fabricate GTM IDs; - fabricate successful realtime events; - fabricate consent evidence; - use fake production data as evidence.

Tests may use explicit fixtures labeled as fixtures.

Production evidence must come from real API/runtime responses.

55. DEPENDENCY MANAGEMENT

Do not guess dependency versions.

At execution time:

```
npm view <package> version
```

and consult official package documentation.

Pin dependencies according to repository security policy and commit lockfiles.

Likely capability classes:

- Google APIs Node client / `googleapis` ;
- MCP official TypeScript server package(s);
- schema validation (`zod`) if required;

- optional browser test framework.

Do not install redundant libraries when native Node 22 capabilities suffice.

56. API VERSION POLICY

Google APIs change.

Before implementation: - inspect latest official Admin API docs; - use current GA4 APIs; - avoid deprecated conversion-event APIs; - inspect GTM API v2; - inspect current Consent Mode v2 behavior; - inspect current MCP SDK stable release.

Record the verification date in the ADR.

57. PRIVACY ACCEPTANCE CRITERIA

All must pass:

- ☐ CookieHub remains consent source of truth.
 - ☐ No analytics data goes to Google before analytics consent.
 - ☐ Advanced Consent Mode is not enabled by default.
 - ☐ `ad_storage` denied by default.
 - ☐ `ad_user_data` denied by default.
 - ☐ `ad_personalization` denied by default.
 - ☐ Analytics event schema contains no PII.
 - ☐ Query strings are stripped from route analytics.
 - ☐ OAuth callback URLs are excluded from analytics.
 - ☐ password-reset URLs are excluded/sanitized.
 - ☐ no arbitrary EventMesh payload reaches GA.
 - ☐ no financial-sensitive payload reaches GA.
-

58. SECURITY ACCEPTANCE CRITERIA

All must pass:

- ☐ Google OAuth client secret server-only.
- ☐ Refresh tokens encrypted at rest.
- ☐ Dedicated token encryption key.
- ☐ OAuth state validation.
- ☐ Exact redirect URI.

- ☐ Incremental scopes.
 - ☐ Read/write/publish permissions separated.
 - ☐ Remote MCP authenticated.
 - ☐ Remote MCP Origin/Host validated.
 - ☐ Owner/TOTP required for publish.
 - ☐ Approval bound to plan hash.
 - ☐ Approval single-use/expiring.
 - ☐ no raw token in logs.
 - ☐ no secret in MCP tool result.
 - ☐ rate limits active.
 - ☐ GTM fingerprint concurrency check active.
 - ☐ destructive operations blocked by default.
-

59. FUNCTIONAL ACCEPTANCE CRITERIA

All must pass:

- ☐ existing GA property discovered/adopted.
 - ☐ existing production web stream discovered/adopted.
 - ☐ no duplicate GA resources.
 - ☐ existing or approved GTM container adopted/created exactly once.
 - ☐ desired-state reconciliation is idempotent.
 - ☐ dry-run produces deterministic plan.
 - ☐ second identical apply produces NOOP.
 - ☐ GTM workspace preview passes.
 - ☐ container version created from approved workspace.
 - ☐ publication requires approval.
 - ☐ realtime post-consent event verified.
 - ☐ SPA route event verified.
 - ☐ consent revocation verified.
 - ☐ rollback path verified/documented.
-

60. ARCHITECTURE ACCEPTANCE CRITERIA

- ☐ component follows CAPITAL-AI manifest conventions.
- ☐ new ADR exists.
- ☐ EventMesh contracts conform.

- [] no forbidden direct EventMesh implementation dependency.
 - [] Documentary updated.
 - [] Traceability updated.
 - [] PlatformDirector limitations truthfully represented.
 - [] `server.ts` remains thin.
 - [] no parallel analytics implementation remains after accepted cleanup.
 - [] build/test/predeploy checks pass.
-

61. REQUIRED FINAL CLAUDE REPORT

When complete, return a report with exactly these sections:

1. Baseline

- main SHA;
- platform version;
- existing GA/CookieHub state.

2. Files changed

Table: - path; - purpose; - architecture owner.

3. ADR

- ADR ID;
- decision;
- implementation status.

4. MCP

- transport;
- tools;
- resources;
- authorization.

5. Google OAuth

- scopes;
- credential profiles;
- token storage;
- outstanding human actions.

6. GA Admin

- discovered resource IDs;
- changes applied;
- no-op items.

7. GTM

- account/container/workspace/version;
- publish status;
- rollback version.

8. Consent

- CookieHub mode;
- Consent Mode type;
- pre-consent evidence;
- post-consent evidence;
- revocation evidence.

9. Security

- IAM;
- TOTP;
- token encryption;
- CSP/CORS changes;
- negative tests.

10. Tests

Show commands and exact results.

11. Traceability

Show updated contracts/events/docs.

12. External production actions

Separate: - Google; - CookieHub; - Render; - Supabase.

13. Residual risks

No hidden or implied risks.

14. Merge recommendation

One of: - `READY_FOR_REVIEW` - `BLOCKED` - `NOT_READY`

Do not auto-merge.

62. REFERENCE IMPLEMENTATION FLOW

Conceptual pseudocode:

```
const current = await discovery.readCurrentState();
const desired = await desiredState.load();

const plan = reconciliation.build({
  current,
  desired,
  policies: [
    privacyPolicy,
    oauthScopePolicy,
    mutationPolicy,
    publishPolicy
  ]
});

if (plan.hasPrivacyRegression) {
  throw new PolicyError("ANALYTICS_CONSENT_REGRESSION");
}

if (request.dryRun) {
  return plan;
}

approval.assertValid({
  approvalId: request.approvalId,
  planHash: plan.hash,
  actor,
  requiredStepUp: plan.requiresPublish
});

const result = await executor.apply(plan);
const verification = await verifier.verify(result);

if (!verification.passed) {
  await evidence.recordFailure(...);
  throw new VerificationError();
}

await evidence.recordSuccess(...);
return result;
```

63. REPOSITORY MIGRATION PRINCIPLE

Do not implement a big-bang rewrite.

Preferred PR decomposition if scope becomes too large:

PR A — control plane foundation

- ADR;
- desired state;
- OAuth read-only;
- read MCP;
- reconciliation;
- tests.

PR B — GA/GTM write plane

- configurator;
- workspace;
- preview;
- versioning;
- approvals.

PR C — consent/runtime cutover

- Basic Consent Mode v2;
- consent-gated GTM;
- frontend analytics façade;
- browser tests.

PR D — production evidence / cleanup

- postchecks;
- old gtag removal;
- documentation completion.

If the repository owner requested one PR, still preserve these as separate commits and explicit review stages.

64. CURRENT EXTERNAL FACTS TO VERIFY, NOT BLINDLY TRUST

At implementation time Claude should verify these facts against official sources:

1. Google Analytics Admin API supports programmatic GA4 configuration.
2. Creating properties/data streams requires `analytics.edit`.
3. Google Tag Manager API uses dedicated scopes for: - editing containers; - editing container versions; - publishing.
4. official Google Analytics MCP remains read-only.

5. Google Consent Mode v2 contains: - `analytics_storage` ; - `ad_storage` ; - `ad_user_data` ; - `ad_personalization` .
6. Basic Consent Mode blocks Google tags and transfers no data before user interaction/ consent.
7. Advanced Consent Mode may send measurements without cookies before consent.
8. CookieHub current release supports Consent Mode v2 and a Basic mode.
9. current MCP remote transport recommendation is Streamable HTTP.

If current official documentation contradicts this specification, record the discrepancy in the ADR and follow the current official behavior while preserving CAPITAL-AI's stricter privacy invariant.

65. AUTHORITATIVE REFERENCES

Use official documentation as primary sources.

Google Analytics

- Google Analytics Admin API overview
<https://developers.google.com/analytics/devguides/config/admin/v1>
- Google Analytics Admin REST API
<https://developers.google.com/analytics/devguides/config/admin/v1/rest>
- Data stream create / `analytics.edit` scope
<https://developers.google.com/analytics/devguides/config/admin/v1/rest/v1beta/properties.dataStreams/create>
- Google Analytics Data API
<https://developers.google.com/analytics/devguides/reporting/data/v1>
- Official Google Analytics MCP
<https://developers.google.com/analytics/devguides/MCP>

Google OAuth

- OAuth 2.0 for web-server applications
<https://developers.google.com/identity/protocols/oauth2/web-server>
- OAuth security best practices
<https://developers.google.com/identity/protocols/oauth2/resources/best-practices>

Google Tag Manager

- GTM API authorization
<https://developers.google.com/tag-platform/tag-manager/api/v2/authorization>

- GTM REST API v2
<https://developers.google.com/tag-platform/tag-manager/api/reference/rest>
- Create tag
<https://developers.google.com/tag-platform/tag-manager/api/reference/rest/v2/accounts.containers.workspaces.tags/create>
- Create container version
https://developers.google.com/tag-platform/tag-manager/api/reference/rest/v2/accounts.containers.workspaces/create_version

Consent Mode

- Consent Mode overview
<https://developers.google.com/tag-platform/security/concepts/consent-mode>
- Configure Consent Mode on websites
<https://developers.google.com/tag-platform/security/guides/consent>

CookieHub

- Consent Mode v2
<https://docs.cookiehub.com/installation/consent-mode-v2>
- Google Tag Manager integration
<https://docs.cookiehub.com/installation/google-tag-manager>

MCP

- MCP architecture
<https://modelcontextprotocol.io/docs/learn/architecture>
- MCP SDKs
<https://modelcontextprotocol.io/docs/sdk>
- MCP transport specification
<https://modelcontextprotocol.io/specification/2025-11-25/basic/transports>
- TypeScript SDK documentation
<https://ts.sdk.modelcontextprotocol.io/>

66. FINAL EXECUTION COMMAND TO CLAUDE

Begin now.

Do not ask for information that can be discovered from: - the repository; - Google APIs after OAuth; - current official documentation; - existing CAPITAL-AI manifests/runbooks.

Start with **PHASE 0 — PRE-FLIGHT**.

Before any external production mutation, produce the required reconciliation plan and evidence.

Preserve the current consent behavior until the replacement has passed the strict no-pre-consent-data test.

Implement code, tests, manifests, ADRs, documentation and handoff artifacts.

Use fail-closed behavior.

Do not fabricate successful external configuration.

Do not auto-merge.

End with the required final report from Section 61.

CAPITAL-AI — Google Marketing MCP Architecture

Quelle: docs/architecture/CAPITAL_AI_GOOGLE_MARKETING_MCP_ARCHITECTURE.md

CAPITAL-AI — Google Marketing MCP Architecture

Claude Implementation Profile, decoupled from ESS-0014

Document type: Implementation Architecture / Claude Code Handoff

Normative authority: ESS-0014 + ESS-0014-CONTRACTS

Related ADR: ADR-0035

Date: 2026-08-03

Status: IMPLEMENTATION PROFILE — not a replacement for ESS/IAM authority

0. Executive Directive

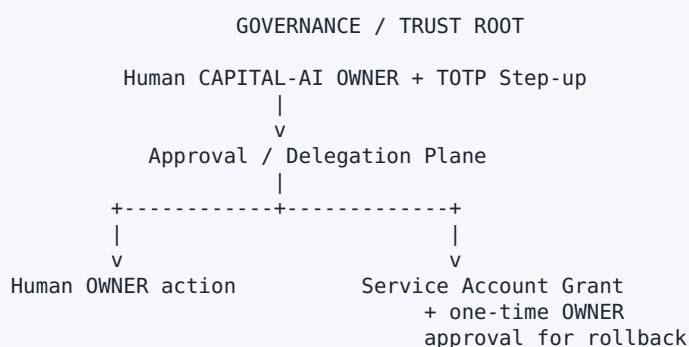
This document instructs Claude Code how to implement the Google Marketing integration without making Claude part of the trust root.

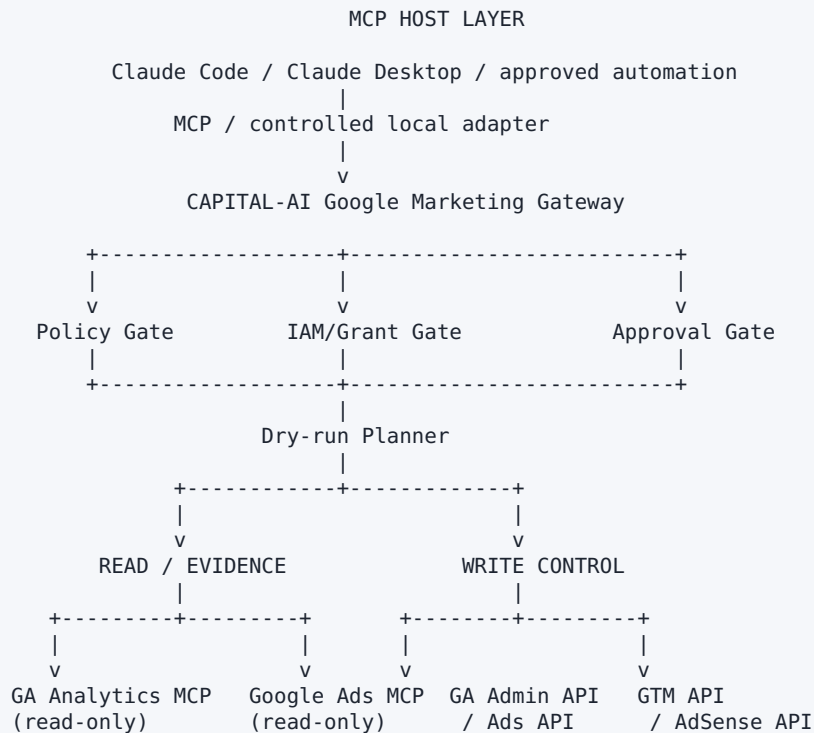
Claude **MUST** treat ESS-0014 as normative and this document as an implementation profile.

Claude **MUST NOT**:

- invent or grant OWNER privileges;
- bypass CAPITAL-AI TOTP step-up;
- create self-approved rollback artifacts;
- grant service-account capabilities;
- downgrade CookieHub, Consent Mode, CSP or protected-change controls without an explicit approved protected-change flow;
- turn an official read-only Google MCP into an undocumented mutation proxy.

1. Target Architecture





2. Component Boundary

Suggested implementation root:

```

server/googleMarketing/
├── principals/
│   ├── principalResolver.ts
│   ├── serviceAccountGrantStore.ts
│   └── approvalStore.ts
├── policy/
│   ├── protectedChangeClassifier.ts
│   ├── marketingPolicyGate.ts
│   └── impactDisclosure.ts
├── mcp/
│   ├── googleAnalyticsReadAdapter.ts
│   ├── googleAdsReadAdapter.ts
│   └── toolRegistry.ts
├── providers/
│   ├── gaAdminAdapter.ts
│   ├── gtmAdapter.ts
│   ├── googleAdsWriteAdapter.ts
│   └── adsenseAdapter.ts
├── drift/
│   ├── fingerprint.ts
│   └── reconciler.ts
├── audit/
│   └── marketingAudit.ts
└── types.ts
  
```

Do not create these files merely to satisfy the tree. Implement only when functionality and tests are supplied.

3. Official Google MCP Read Plane

Google Analytics MCP

Use the official Google Analytics MCP/Data API toolset for reporting, metadata, realtime reports and compatibility checks.

Treat as read-only.

Google Ads MCP

Use the official Google Ads MCP for customer discovery, GAQL reporting and resource metadata.

Current documented release is read-only and supports OAuth 2.0 or service-account authentication. Do not infer write capabilities.

Rule

Provider MCP output is evidence/context. It does not constitute CAPITAL-AI approval to mutate provider state.

4. Mutating Google APIs

Where provider configuration must be changed, implement explicit adapters against the authoritative API:

- GA4 configuration -> Google Analytics Admin API;
- Tag/container lifecycle -> Google Tag Manager API;
- Google Ads writes -> Google Ads API, only after a specific write capability is approved;
- AdSense supported management/reporting operations -> AdSense Management API;
- browser consent -> CookieHub + Google Consent Mode, never an AI-side direct override.

Every adapter method must declare:

```
risk: 'read' | 'write' | 'publish' | 'destructive';
requiredCapability: GoogleMarketingCapability;
dryRunDefault: true;
```

5. Human OWNER Flow

```
Request mutation
-> resolve Supabase identity
-> checkAdminAccess(... OWNER_ONLY_ROLES)
-> if protected/publish/destructive: requireStepUp()
-> produce dry-run + impact disclosure
-> ask for explicit confirmation
-> create short-lived approval
-> re-check live fingerprint
-> apply
```

```
-> verify provider state  
-> audit + traceability
```

An approval must not be reusable across changed fingerprints.

6. Service Account Flow

Principal model

Service accounts are separate machine principals. Never store `iam_role='owner'` for a service account.

Grant administration

Only a Human OWNER with fresh TOTP step-up can:

- create grant;
- change scope;
- change capability;
- extend expiry;
- revoke grant;
- issue a one-time rollback approval.

Runtime flow

```
service account credential  
-> verify principal  
-> resolve active grants  
-> exact capability check  
-> resource scope check  
-> expected fingerprint check  
-> if rollback: consume one-time OWNER approval  
-> execute  
-> audit
```

No self-delegation and no transitive delegation.

7. Protected Rollback UX/API Contract

For interactive Claude flows, before any protected rollback Claude MUST return an impact summary and obtain explicit confirmation.

Required warning classes:

PRIVACY:	consent behavior may change
ANALYTICS:	measurements/history continuity may change
ADS:	monetization/ad serving may stop or change
SECURITY:	CSP/XSS attack surface may increase
COMPLIANCE:	audit/traceability/CMP evidence may become invalid
RUNTIME:	production/AMP/SEO behavior may regress

The prompt must include the exact protected resources and intended diff.

Headless service accounts replace the interactive question only with a matching one-time OWNER Approval Artifact created after the same impact disclosure.

8. Strict CSP Implementation

Required server behavior

1. Generate cryptographically random nonce for every HTML response.
2. Attach nonce to `res.locals` or equivalent request context.
3. Set Strict CSP header using that nonce.
4. Read the built `dist/index.html` as a template.
5. Replace only the dedicated nonce placeholder with the request nonce.
6. Do not let `express.static` serve `index.html` directly, because that would bypass nonce injection.
7. Send dynamic HTML.

AdSense-compatible script core:

```
script-src 'nonce-{nonce}' 'unsafe-inline' 'unsafe-eval' 'strict-dynamic' https: http:
object-src 'none'
base-uri 'none'
```

CookieHub explicit endpoints remain present in the relevant directives.

Nonce requirements

- crypto-grade randomness;
 - `128` =128-bit entropy;
 - unique per HTML response;
 - no static env var nonce;
 - no shared global nonce;
 - same nonce in CSP and script tags for one response.
-

9. Current HTML Hooks

The HTML template uses `__CSP_NONCE__` as server-replaced placeholder.

Protected scripts:

- CookieHub SDK;
- `/cookiehub-init.js`;

- AdSense async loader;
- AMP Auto Ads extension loader;
- `/google-analytics-consent.js`;
- Vite/React module entry.

Claude must preserve these hooks unless a protected change is explicitly approved.

10. CookieHub / Consent

CookieHub remains source of truth.

CAPITAL-AI target consent state:

```
analytics_storage <- analytics consent
ad_storage        <- marketing consent
ad_user_data      <- marketing consent
ad_personalization <- marketing consent
```

The implementation must maintain the application's Basic Consent Mode privacy posture: no Google analytics/marketing data collection before the required consent state.

Do not independently set Google defaults to granted.

11. AdSense Runtime

The standard non-AMP AdSense loader remains the browser integration for the React/Vite application.

Do not assume that inserting the AMP extension into a non-AMP SPA activates AMP Auto Ads.

AdSense CSP tests must verify:

- loader is not CSP blocked;
 - child scripts trusted through strict-dynamic can execute;
 - generated ad frames/resources are not broken by overly narrow frame/img/connect rules;
 - consent behavior remains compliant.
-

12. AMP Runtime

The repository currently contains AMP Auto Ads hooks in the base markup because they were explicitly requested.

Before classifying AMP as operational, Claude must implement or locate a valid AMP document/route and run AMP validation.

Recommended separation:

```
/          -> React/Vite non-AMP SPA  
/amp/...   -> valid AMP document(s), if the product actually requires AMP
```

If no valid AMP route is introduced, document the hooks as dormant/non-operative and do not claim AMP monetization success.

13. Persistence Model (Target)

Suggested tables/concepts; exact Supabase implementation requires production handoff and migration review:

```
marketing_service_accounts  
marketing_capability_grants  
marketing_change_approvals  
marketing_change_audit  
marketing_resource_fingerprints
```

Security rules:

- service-role/server access only for machine credential material;
- no browser write access;
- RLS fail-closed;
- owner identity always derived from verified bearer session;
- grant mutation requires OWNER + step-up;
- secrets encrypted at rest using dedicated key material.

Do not apply production Supabase migrations from a development-only environment without the established production handoff.

14. MCP Tool Surface

Read tools:

```
google_marketing.list_accounts  
google_marketing.analytics.report  
google_marketing.ads.report  
google_marketing.resource_metadata  
google_marketing.drift.inspect
```

Planning tools:

```
google_marketing.plan_change  
google_marketing.explain_impact  
google_marketing.preview_csp
```

Mutating tools:

google_marketing.apply_change
google_marketing.publish_change
google_marketing.rollback_change

Owner delegation tools:

google_marketing.service_account.grant
google_marketing.service_account.revoke
google_marketing.approval.issue

The final names may follow repository naming contracts, but semantics must remain separate.

15. Tool Authorization Matrix

Operation	OWNER	Service Account	Additional gate
read/report	yes	read grant	none beyond identity/ grant
plan/dry-run	yes	plan grant	none beyond identity/ grant
apply non-destructive	yes	apply grant	approval according to risk
publish	OWNER + step-up	publish grant	owner-approved publish artifact
rollback	OWNER + step-up	rollback grant	explicit impact + one-time OWNER approval
grant/revoke service rights	OWNER + step-up	never	human OWNER only
rotate privileged credentials	OWNER + step-up	credentials.rotate if scoped	approval + audit

16. Fingerprint / Drift Model

Every controlled Google resource has a normalized fingerprint. Mutation request supplies `expectedFingerprint`.

If live fingerprint differs:

DENY -> regenerate plan -> redisclose impact -> reapprove

Never apply a stale plan.

17. Audit Events

Before registering new events, check ESS-0013 Event Catalog for semantically equivalent events.

Desired semantics:

```
ProtectedChangeRequested  
ProtectedChangeDenied  
ProtectedChangeApproved  
ProtectedChangeApplied  
ProtectedChangeVerified  
ServiceAccountGrantChanged  
GoogleMarketingDriftDetected
```

Event payloads contain references/fingerprints, never secrets.

18. Implementation Phases for Claude Code

Phase A — Preflight

- read current main;
- verify ADR/ESS registry;
- verify CookieHub/GA/AdSense runtime;
- verify IAM + Step-up implementation;
- identify existing Event/Traceability contracts;
- run tests/build baseline.

Phase B — CSP

- implement per-response nonce;
- dynamic HTML template injection;
- CookieHub explicit CSP targets;
- strict-dynamic AdSense-compatible policy;
- add CSP tests;
- verify CookieHub regression.

Phase C — Protected Change Gate

- implement classifier;
- impact disclosure;
- owner/step-up authorization;
- approval artifact;
- fingerprint check;
- audit.

Phase D — Service Accounts

- implement separate principal/credential model;
- capability grant store;
- OWNER-only grant management;
- one-time rollback approval;
- tests.

Phase E — Google MCP Federation

- wire official Analytics MCP read plane;
- wire official Ads MCP read plane;
- build provider write adapters only where required;
- preserve dry-run default.

Phase F — Production Evidence

- CookieHub banner;
- consent gating;
- CSP violation report;
- AdSense serving check;
- nonce uniqueness;
- owner denial matrix;
- service-account denial matrix;
- traceability update;
- ADR completion decision.

19. Stop Conditions for Claude

Stop before write if:

- requested operation is protected and impact confirmation is absent;
 - requester is not authorized;
 - Step-up is missing;
 - service grant is missing/expired;
 - rollback approval is missing/used/expired;
 - live fingerprint drifted;
 - provider API scope is ambiguous;
 - operation requires a production-only Supabase/Google/Render configuration change without production handoff;
 - tests would be bypassed rather than fixed.
-

20. Provider Baseline — Verify Again at Execution Time

As of 2026-08-03:

- Google Analytics MCP exposes reporting/read capabilities and cannot edit Analytics configuration;
- Google Ads MCP current release is read-only and supports OAuth 2.0 or service account authentication;
- Google AdSense CSP guidance supports Strict CSP with a random nonce and `strict-dynamic` because AdSense domains change;
- CookieHub requires its documented script/style/connect hosts, including `cookiehub.net` and `cdn.cookiehub.eu` in `connect-src` since CookieHub 2.8.4.

Claude MUST re-check provider documentation before production cutover.

21. Definition of Implementation Complete

Do not mark complete until:

- repository build/tests pass;
- Strict CSP nonce works in production-like runtime;
- CookieHub still renders;
- GA remains consent-gated;
- AdSense is not CSP-blocked;
- service accounts cannot self-elevate;
- non-OWNER human cannot rollback;
- OWNER rollback requires Step-up and explicit impact confirmation;
- service-account rollback requires scoped grant + one-time OWNER approval;
- audit/traceability evidence exists;
- production handoff is documented.

CAPITAL AI GOOGLE MARKETING MCP TOPOLOGY

Quelle: docs/architecture/CAPITAL_AI_GOOGLE_MARKETING_MCP_TOPOLOGY.md



+ CAPITAL-AI DOCUMENTARY

AUTONOMOUS AI DOCUMENT HYGIENIST • VERSION 0.5.4

System-Metadaten	Spezifikation
Plattform-Identität	Capital-AI Documentary (V0.5.4)
Gründer & Inhaber	Sven Kulessa
Zentrale E-Mail	sven.kulessa@capital-ai.online
Echtheits-Emblem	▣ CAPITAL-AI CORE
Status	Revisionssicher verifiziert & bereinigt

Google Marketing MCP — Topologie für Marketing-Monitoring

Document ID

ARCH-TOPO-0001

Bezug

- `.ai/skills/ESS-0014-Google-Marketing-MCP-Governance.md` (normativ)
- `docs/adr/ADR-0035-protected-google-marketing-integration-strict-csp.md`
- `docs/adr/ADR-0040-csp-runtime-remediation-safe-rollout.md`
- `docs/adr/ADR-0042-basic-consent-mode-v2-google-tag-gating.md`
- `docs/architecture/CAPITAL_AI_GOOGLE_MARKETING_MCP_ARCHITECTURE.md` (Implementierungsprofil)
- `.mcp.json`, `docs/seo/SEO_MANAGEMENT_ROADMAP.md`

Status

Aktiv — Topologie-Übersicht zum Repository-Stand `1809f03` (08.08.2026).

Dieses Dokument ist **deskriptiv**: es zeigt, was heute real läuft und was spezifiziert, aber nicht implementiert ist. Es erteilt keine Berechtigungen und ersetzt weder ESS-0014 noch ADR-0035.

1. Gesamttopologie

Legende: implementiert und im Betrieb spezifiziert, **nicht** implementiert

```

flowchart TB
    subgraph CONSENT["① Consent Trust Root"]
        direction TB
        CH["CookieHub CMP <br/>Source of Truth"]
        CM["Consent Mode v2 – Basic <br/>alle Signale default 'denied'"]
        CH --> CM
    end

    subgraph BROWSER["② Browser – capital-ai.online"]
        direction TB
        BRIDGE["google-analytics-consent.js <br/>First-Party Consent Bridge"]
        GA4T["GA4 Tag <br/>nur bei analytics = granted"]
        ADST["AdSense <br/>nur bei marketing = granted"]
        BRIDGE --> GA4T
        BRIDGE --> ADST
    end

    subgraph PLANES["③ Google Data Planes"]
        direction LR
        P1["GA4 Property "]
        P2["AdSense "]
        P3["Search Console "]
        P4["Google Ads "]
    end

    subgraph READ["④ MCP Read / Evidence Plane – nur lesend"]
        direction LR
        M1["ga4-analytics <br/>.mcp.json"]
        M2["search-console "]
        M3["ads / adsense "]
    end

    subgraph HOST["⑤ MCP Host"]
        CC["Claude Code <br/>Monitoring & Reporting"]
    end

    subgraph WRITE["⑥ Write / Admin Gateway – ESS-0014 / ADR-0035"]
        direction TB
        G1["Policy Gate"] --> G2["IAM / Grant Gate"]
        G2 --> G3["OWNER Approval + TOTP Step-up"]
        G3 --> G4["Dry-run Planner"]
        G4 --> G5["Fingerprint"]
        G5 --> G6["Apply"]
        G6 --> G7["Verify"]
        G7 --> G8["Audit Trail"]
    end

    subgraph ADMIN["⑦ Google Admin Connector "]
        direction LR
        A1["GA Admin API"]
        A2["Tag Manager API"]
        A3["Ads / AdSense Write"]
    end

    CM -->|"gating"| BRIDGE
    GA4T --> P1
    ADST --> P2
    P1 --> M1
    P3 --> M2
    P4 --> M3

```

```
M1 --> CC
M2 --> CC
M3 --> CC
CC -->|"Mutationen NIE direkt"| G1
G8 --> A1
G8 --> A2
G8 --> A3
A1 --> P1
A3 --> P4
```

2. Verbindliche Leseregeln der Grafik

- 1. **Ebene ① ist der Trust Root, nicht Google.** Ohne CookieHub-Opt-in wird kein Google-Tag geladen und kein Google-Request ausgelöst. Consent Mode v2 läuft im **Basic Mode**; Advanced Mode mit cookieless pings ist ausdrücklich ausgeschlossen (ADR-0042).
- 2. **Ebene ④ ist strikt lesend.** Der offizielle Google-Analytics-MCP wird als Read-/Evidence-Plane behandelt. Es werden keine Schreibfähigkeiten erfunden (ESS-0014).
- 3. **Der Pfad ⑤ → ⑥ ist gestrichelt und heute nicht vorhanden.** Mutationen dürfen niemals direkt am MCP hängen, sondern ausschließlich durch die vollständige Gate-Kette Policy → IAM/Grant → OWNER-Approval+TOTP → Dry-run → Fingerprint → Apply → Verify → Audit.
- 4. **Claude ist Implementierungs-/MCP-Host, keine Autorisierungsinstanz.** Weder Modellidentität noch Repository-Schreibrechte ersetzen einen CAPITAL-AI-OWNER.

3. Realer Implementierungsstand (Stand 1809f03)

Baustein	Status	Nachweis
CookieHub CMP	■	index.html , public/cookie-hub-init.js
Consent Bridge / Consent Mode v2 Basic	■	public/google-analytics-consent.js , ADR-0042
GA4 Tag, consent-gated	■	index.html Meta ga-measurement-id , Bridge-Injektion
AdSense, consent-gated	■	index.html Meta adsense-publisher-id
MCP Read-Server ga4-analytics	■	.mcp.json
Search-Console-Read-Plane	■	kein Eintrag in .mcp.json
Ads-/AdSense-Read-Plane	■	dito
Write-/Admin-Gateway (⑥)	■	server/googleMarketing/ existiert nicht
Google Admin Connector (⑦)	■	dito
Invarianten-Gate im Build	■	scripts/security/verifyGoogleMarketingInvariants.ts , .github/

Baustein	Status	Nachweis
		workflows/google-marketing-protected-change.yml

Von sieben Ebenen sind ① **bis** ⑤ **produktiv**, ⑥ **und** ⑦ **ausschließlich spezifiziert**.

4. Erweiterungspunkte

Die Topologie ist bewusst additiv erweiterbar:

- **Neue Read-Quelle** (z. B. Search Console): Eintrag in `.mcp.json` ergänzen, Zugangsdaten über die Umgebungs-Secret-Konfiguration bereitstellen, Kategorie/Consent-Bezug im `DATENSCHUTZ_PROTOKOLL.md` dokumentieren. Kein Eingriff in Ebene ① oder ② nötig.
- **Neuer Consent-pflichtiger Tag**: ausschließlich über die Bridge in Ebene ②, gekoppelt an eine CookieHub-Kategorie — niemals als unbedingtes Script im `<head>`.
- **Erste Schreibfähigkeit**: erfordert Ebene ⑥ vollständig, einen eigenen ADR und eine OWNER-Freigabe. Eine Teilimplementierung der Gate-Kette ist ausdrücklich unzulässig.

Der geplante Ausbaupfad ist in `docs/seo/SEO_MANAGEMENT_ROADMAP.md` terminiert (D5 Search Console, H2 Google Admin Connector).

Fußnote zur Header-Version

Der Documentary-Header nennt „Version 0.5.4“, während `package.json` auf `0.6.0` steht. Diese Abweichung besteht identisch in allen zehn Bestandsdokumenten mit diesem Header und wird hier bewusst unverändert übernommen; ihre Pflege gehört der Documentary-/VersionManager-Engine, nicht diesem Dokument.

Brand Persona, Copywriting & Content-Strategie

Quelle: docs/content-creator/CONTENT_STRATEGY.md

Brand Persona, Copywriting & Content-Strategie

Project: CAPITAL-AI
Brand Voice: Expert Partner (Sachlich, Präzise & Mathematisch)
Classification: Public Facing / Regulatory Compliant

Marken-Tonalität & Persona (Brand Voice)

CAPITAL-AI / CAPITAL-AI tritt im Bereich der Finanzanalyse als verlässlicher, wissenschaftlicher und mathematisch-präziser Partner auf.

- **Wir verwenden:** Eine sachliche, objektive und datengetriebene Sprache. Alle Berichte, Signale und Analysen beruhen auf realen Formeln und belegbaren Datenreihen.
- **Wir meiden:** Reißerische Werbesprüche, unrealistische Rendite-Versprechungen, emotionale Ausrufezeichen oder künstlich übertriebene "AI-Slop"-Begriffe (wie "stellar", "jaw-dropping", "gorgeous").
- **Einfache und menschliche Bezeichnungen:** Wir nutzen einfache, demütige und verständliche Begrifflichkeiten für alle UI-Elemente. Beispielsweise verwenden wir "Uhrzeit" statt "Solar-Orbit-Tracker" und "Aktienscreener" statt "Reichtums-Prophet".

BaFin- & MiFID II-konforme Schreibweisen

Jede qualitative oder quantitative Darstellung von Marktdaten, Berechnungs-Scores oder simulierten Portfolien muss zwingend mit dem rechtlichen Haftungsausschluss versehen werden:

Formulierungen zu vermeiden (Irreführend)	Erlaubte Formulierungen (Faktenbasiert)	Rechtlicher Hintergrund
„Garantiertes passives Einkommen mit diesem Setup!“	„Historisch berechnete Performance-Kennzahlen im Backtest.“	Vermeidung von unzulässigen Gewinnversprechen (BaFin-Vorgaben).
„Dieses KI-Modell weiß genau, wohin der Kurs morgen geht.“	„Quantitative Wahrscheinlichkeiten auf Basis mathematischer Indikatoren.“	Wahrheitsgemäße Kennzeichnung von Prognose-Modellen.
„Die beste Investment-Plattform aller Zeiten!“	„Ein modulares Analyse-Werkzeug nach Value-Investing-Kriterien.“	Verbot irreführender Alleinstellungsansprüche (§ 5 UWG).

Standardisierte Disclaimer & Währungsangaben

Standard-Haftungsausschluss (DEUTSCH)

HINWEIS: Keine Anlageberatung. Die gezeigten Daten stellen ausschließlich quantitative Berechnungen dar. Die endgültige Anlageentscheidung liegt vollumfänglich beim Nutzer. Währungsangaben erfolgen standardmäßig in **EUR (€)** oder **USD (\$)**.

Standard Disclaimer (ENGLISH)

NOTICE: No financial advice. The shown data represents quantitative calculations only. Investment decisions are made solely at the risk of the user. Currency outputs default to **EUR (€)** or **USD (\$)**.

Visuelle Content-Strukturierung & Rhythmus

- **Weißraum & Lesbarkeit:** Verwende großzügige Abstände (Generous Negative Space) und responsive Bento-Grid-Layouts, um die Informationsdichte auf Mobilgeräten zu minimieren.
- **Klare Badge-Klassifizierung:** Nutze eindeutige Labels zur Kennzeichnung von Risikostufen (z.B. **Niedrig** in Cyber-Grün, **Hoch** in Rot) und Abonnement-Klassen (**Enterprise** in Gold), um den Status von Datenzeilen ohne kognitiven Ballast lesbar zu machen.

Affiliate / Referral Block (Owner-requested)

Quelle: docs/content-creator/packages/graham-fair-value-check/AFFILIATE_REFERRAL.md

Affiliate / Referral Block (Owner-requested)

Text (DE) - Standard

Tritt Kraken Pro bei, und wir können beide Prämien erhalten.

Verwende meinen Link unten, oder meinen Referral-Code **yc4ggk3f**, um dich zu registrieren.

<https://proinvite.kraken.com/9f1e/xghjfdv4>

Kurzvariante (Captions / Overlays)

Werbung / Partner: Kraken Pro – Code **yc4ggk3f** → <https://proinvite.kraken.com/9f1e/xghjfdv4>

Verwendung (aktuell)

Kanal	Integration
X Thread (Graham)	Tweet 8 – klar als Werbung/Partner
X Imagine Short	Im Tweet-Text + optional Overlay im Video
LinkedIn	Am Ende des Posts unter „Partner-Hinweis (Werbung)“
Instagram Caption	Am Ende der Caption unter „Werbung / Partner“
TikTok / Reels Caption	Am Ende der Caption
Facebook	Am Ende unter „Werbung / Partner“
Bildungs-Voiceover / Thumbnails	Nicht mischen (außer Owner will es explizit)

Compliance

Affiliate-Links sind Werbe-/Partnerinhalte. Bei Veröffentlichung als **Werbung** kennzeichnen, sofern gesetzlich erforderlich. Bildungsclaims und Score-Erklärungen bleiben davon unberührt.

ContentPackage — Benjamin Graham Fair Value Check bei CAPITAL-AI

Quelle: docs/content-creator/packages/graham-fair-value-check/CONTENT_PACKAGE.md

ContentPackage — Benjamin Graham Fair Value Check bei CAPITAL-AI

Status: draft → owner-approved

AI-Authorship: ai_assisted

Financial-Claim-Check: PASS (keine Gewinnversprechen, keine Prognosen)

1. Master-Content (Blog / Educational Article)

Titel

Benjamin Graham Fair Value Check bei CAPITAL-AI – so funktioniert die quantitative Bewertung

Text

CAPITAL-AI stellt Investoren und Analysten ein modulares Analyse-Werkzeug zur Verfügung, das unter anderem einen Fair-Value-Check nach den Prinzipien von Benjamin Graham berechnet. Der Check ist rein quantitativ und basiert auf nachvollziehbaren Formeln sowie belegbaren Marktdaten.

Was wird berechnet?

Der Fair-Value-Check kombiniert klassische Graham-Kennzahlen mit aktuellen Marktdaten:

- Earnings Power und historische Gewinnentwicklung
- Buchwert und Sicherheitsmarge
- Multiplikatoren im historischen und sektoralen Kontext
- Risikoadjustierung über Volatilitäts- und Makro-Indikatoren

Das Ergebnis ist ein numerischer Fair-Value-Bereich sowie eine relative Einordnung zum aktuellen Kurs. Alle Berechnungen erfolgen serverseitig auf Basis realer Datenquellen. Es werden keine simulierten oder hypothetischen Werte verwendet.

Wie ist das Ergebnis zu lesen?

- Ein Kurs unter dem berechneten Fair-Value-Bereich zeigt eine positive Sicherheitsmarge nach Graham-Logik.
- Ein Kurs darüber signalisiert eine engere oder negative Marge.
- Zusätzliche Confidence- und Evidence-Metriken geben Auskunft über die Datenqualität und die Abdeckung der Eingangsgrößen.

Die Darstellung erfolgt bewusst ohne prognostische Sprache. Es handelt sich um eine mathematische Momentaufnahme, keine Vorhersage zukünftiger Kurse.

Warum dieser Ansatz?

Benjamin Grahams Value-Investing-Prinzipien (Sicherheitsmarge, fundamentale Unterbewertung) lassen sich gut in transparente, nachvollziehbare Formeln überführen. CAPITAL-AI automatisiert diesen Prozess und macht ihn für verschiedene Asset-Klassen (Aktien, ausgewählte Indizes) konsistent anwendbar – immer mit klarer Herkunft der Daten und der Berechnungslogik.

HINWEIS: Keine Anlageberatung. Die gezeigten Daten stellen ausschließlich quantitative Berechnungen dar. Die endgültige Anlageentscheidung liegt vollumfänglich beim Nutzer. Währungsangaben erfolgen standardmäßig in EUR (€) oder USD (\$).

2. LinkedIn-Post

Titel: Benjamin Graham Fair Value Check bei CAPITAL-AI – so funktioniert die quantitative Bewertung

CAPITAL-AI stellt ein modulares Analyse-Werkzeug bereit, das unter anderem einen Fair-Value-Check nach den Prinzipien von Benjamin Graham berechnet.

Der Check kombiniert: - Earnings Power und historische Gewinnentwicklung
- Buchwert und Sicherheitsmarge
- Multiplikatoren im historischen und sektoralen Kontext
- Risikoadjustierung über Volatilitäts- und Makro-Indikatoren

Das Ergebnis ist ein numerischer Fair-Value-Bereich sowie eine relative Einordnung zum aktuellen Kurs – ergänzt um Confidence- und Evidence-Metriken zur Datenqualität.

Die Darstellung erfolgt bewusst ohne prognostische Sprache. Es handelt sich um eine mathematische Momentaufnahme, keine Vorhersage zukünftiger Kurse.

HINWEIS: Keine Anlageberatung. Die gezeigten Daten stellen ausschließlich quantitative Berechnungen dar. Die endgültige Anlageentscheidung liegt vollumfänglich beim Nutzer.

Partner-Hinweis (Werbung):

Tritt Kraken Pro bei, und wir können beide Prämien erhalten.

Link oder Referral-Code **yc4ggk3f**: <https://proinvite.kraken.com/9f1e/xghjfdv4>

3. Instagram - Carousel (5 Slides) + Caption

Slide 1

Benjamin Graham Fair Value Check

bei CAPITAL-AI

Quantitative Bewertung – transparent & nachvollziehbar

Slide 2

Was wird berechnet?

Earnings Power

Buchwert

Sicherheitsmarge

Multiplikatoren

Risikoadjustierung

Slide 3

Ergebnis

Numerischer Fair-Value-Bereich

Relative Einordnung zum Kurs

Confidence-Metrik

Slide 4

Interpretation

Kurs < Fair Value → positive Sicherheitsmarge

Kurs > Fair Value → engere / negative Marge

Slide 5

Keine Prognose.

Nur Mathematik und belegbare Daten.

HINWEIS: Keine Anlageberatung.

Caption

CAPITAL-AI berechnet den Fair-Value-Check nach Benjamin-Graham-Prinzipien – rein quantitativ und transparent.

Alle Werte basieren auf realen Marktdaten. Keine simulierten Zahlen. Keine Kursprognosen.

HINWEIS: Keine Anlageberatung. Die gezeigten Daten sind ausschließlich quantitative Berechnungen. Die Anlageentscheidung liegt beim Nutzer.

Werbung / Partner:

Tritt Kraken Pro bei – wir können beide Prämien erhalten.

Code **yc4ggk3f** oder Link: <https://proinvite.kraken.com/9f1e/xghjfdv4>

ValueInvesting #QuantitativeAnalysis #CAPITALAI #Graham

4. TikTok / Instagram Reels / YouTube Short (45-60 s)

Hook (0-3 s)

„Wie CAPITAL-AI den Graham Fair Value berechnet – ohne Hype.“

Hauptteil (3-45 s)

- Eingangsgrößen (Earnings, Book Value, Margin of Safety)
- Kurze Formel-Übersicht
- Beispiel eines Score-Snapshots (anonymisiert)
- Confidence-Metrik erklären

Abschluss (45-60 s)

„Rein quantitativ. Nachvollziehbar. Keine Prognose.“

Disclaimer einblenden.

Text-Overlays

- „Earnings Power + Buchwert + Sicherheitsmarge“
- „Numerischer Fair-Value-Bereich“
- „Keine Anlageberatung“

Caption (TikTok / Reels)

Graham Fair Value Check bei CAPITAL-AI – rein quantitativ, ohne Hype.

Keine Anlageberatung.

Werbung: Kraken Pro – Code yc4ggk3f → <https://proinvite.kraken.com/9f1e/xghjfdv4>

5. Facebook-Post

CAPITAL-AI berechnet den Fair-Value-Check nach Benjamin-Graham-Prinzipien: Earnings Power, Buchwert, Sicherheitsmarge, Multiplikatoren und Risikoadjustierung. Ergebnis = numerischer Fair-Value-Bereich + Confidence-Metrik. Keine Prognose – nur Mathematik und belegbare Daten.

HINWEIS: Keine Anlageberatung. Die gezeigten Daten stellen ausschließlich quantitative Berechnungen dar. Die endgültige Anlageentscheidung liegt vollumfänglich beim Nutzer.

Werbung / Partner:

Tritt Kraken Pro bei, und wir können beide Prämien erhalten.

Referral-Code **yc4ggk3f** oder Link: <https://proinvite.kraken.com/9f1e/xghjfdv4>

6. Hashtags

Primär: #ValueInvesting #QuantitativeAnalysis #FinancialAnalysis #CAPITALAI #Graham

Sekundär: #InvestmentTools #DataDriven #TransparentFinance #NoHype

7. Provenance / Source Evidence

- Graham, B. – The Intelligent Investor (klassische Prinzipien)
 - CAPITAL-AI interne Scoring-Contracts (Bond/Equity Feature Contracts)
 - Live Market Data Provider (verifiziert)
-

8. Affiliate / Referral

Vollständiger Block und Regeln: siehe `AFFILIATE_REFERRAL.md`.

Zusätzlich: komplettes X-Post + Short-Video zu Imagine auf X → `X_IMAGINE_SHORT.md`.

Media-Prompts & Produktionsanweisungen

Quelle: docs/content-creator/packages/graham-fair-value-check/MEDIA_PROMPTS.md

Media-Prompts & Produktionsanweisungen

1. Thumbnail

Prompt (FLUX / vergleichbar):

Clean professional financial thumbnail, dark navy background, subtle cyan and soft gold accents, minimal mathematical formula overlay showing "Earnings + Book Value + Margin of Safety", elegant modern fintech style, sharp typography, high contrast, no people, no stock photos, no fake charts or numbers, precise and trustworthy aesthetic, 16:9 aspect ratio

Text-Overlay: - Oben klein: CAPITAL-AI - Mitte groß: Graham Fair Value Check - Unten klein: Quantitative Bewertung

Formate: 1280×720 (YouTube), 1200×628 (LinkedIn/Facebook), 1080×1080 (Fallback)

Dateiname: graham-fair-value-check-thumbnail-v1.png

2. Short-Video (45-60 s) — TikTok / Reels / YouTube Shorts

Zeit	Bild / Aktion	Text-Overlay	Voiceover (optional)
0-3 s	Dunkler Hintergrund, Logo	„Graham Fair Value Check“	„Wie CAPITAL-AI den Graham Fair Value berechnet – ohne Hype.“
3-12 s	Drei Bausteine nacheinander	Earnings Power / Buchwert / Sicherheitsmarge	„Drei Kernbausteine: Earnings Power, Buchwert und Sicherheitsmarge.“
12-22 s	Formel-Übersicht	Earnings + Book Value + Margin of Safety	„Kombiniert mit Multiplikatoren und Risikoadjustierung.“
22-35 s	Anonymisierter Score-Snapshot	Numerischer Fair-Value-Bereich + Confidence	„Ergebnis: Fair-Value-Bereich und Confidence-Metrik.“
35-48 s	Gegenüberstellung	Kurs < FV → positive Marge / Kurs > FV → engere Marge	„So wird das Ergebnis gelesen – rein mathematisch.“
48-58 s	Disclaimer	Keine Anlageberatung. Nur quantitative Berechnung.	„Keine Prognose. Keine Anlageberatung.“
58-60 s	Logo	CAPITAL-AI	—

Format: 1080×1920 (9:16)

Dateiname: graham-fair-value-check-short-v1.mp4

Voiceover Short (TTS):

„Wie CAPITAL-AI den Graham Fair Value berechnet – ohne Hype. Drei Kernbausteine: Earnings Power, Buchwert und Sicherheitsmarge. Diese werden mit historischen und sektoralen Multiplikatoren sowie einer Risikoadjustierung kombiniert. Das Ergebnis ist ein numerischer Fair-Value-Bereich und eine Confidence-Metrik. So wird das Ergebnis gelesen – rein mathematisch. Keine Prognose. Keine Anlageberatung. Nur Mathematik und belegbare Daten.“

3. Produktions-Checkliste

- [] Keine echten Kursdaten oder Ticker im Video
- [] Keine Gewinnversprechen oder Zukunftsaussagen
- [] Disclaimer mindestens 2× sichtbar (Anfang + Ende)
- [] Schriftgröße mobil lesbar
- [] Dateien nach Fertigstellung hashen

Controlled Publish-Plan

Quelle: docs/content-creator/packages/graham-fair-value-check/PUBLISH_PLAN.md

Controlled Publish-Plan

Reihenfolge (staffeln)

Tag	Plattform	Format	Zeitpunkt (Empfehlung)
Tag 1	X	7-Tweet-Thread	09:00 – 11:00
Tag 1	LinkedIn	Langer Post	12:00 – 14:00
Tag 1	YouTube	Short	Nachmittag (sobald fertig)
Tag 2	Instagram	Carousel + Reels	11:00 – 13:00
Tag 2	TikTok	Gleicher Short	Nachmittag
Tag 2/3	YouTube	Langes Video	Sobald fertig
Tag 3	Facebook	Post + Video	Vormittag

Regeln

- Immer den freigegebenen Disclaimer verwenden
- Keine nachträglichen Zahlen, Ticker oder Claims
- Media-Dateien hashen und dokumentieren
- Referral nur als separater Post / separater Block (siehe AFFILIATE_REFERRAL.md)
- Erst veröffentlichen, wenn das jeweilige Medium fertig und geprüft ist

Content Package: Benjamin Graham Fair Value Check bei CAPITAL-AI

Quelle: docs/content-creator/packages/graham-fair-value-check/README.md

Content Package: Benjamin Graham Fair Value Check bei CAPITAL-AI

Status: Owner-approved (Content freigegeben)
Typ: educational + partner referral
AI-Authorship: ai_assisted
Compliance: BaFin/MiFID-aligned Bildungsclaims; Referral als Werbung gekennzeichnet
Erstellt / aktualisiert: 2026-08-14 / 2026-08-15

Übersicht

Datei	Inhalt
CONTENT_PACKAGE.md	Master-Texte aller Plattformen (Referral in Captions)
X_THREAD.md	X-Thread inkl. Referral-Tweet 8
X_IMAGINE_SHORT.md	Kompletter X-Post + Short-Video zu Imagine auf X inkl. Referral
VOICEOVER_YOUTUBE_LONG.md	Voiceover langes YouTube-Video
MEDIA_PROMPTS.md	Thumbnail- und Video-Prompts (Graham)
PUBLISH_PLAN.md	Controlled Publish-Reihenfolge
AFFILIATE_REFERRAL.md	Referral-Text, Kurzform, Kanal-Matrix

Referral (Stand)

Code: **yc4ggk3f**
Link: <https://proinvite.kraken.com/9f1e/xghjfdv4>
Kennzeichnung: „Werbung / Partner“ in Captions und X-Posts.

Voiceover-Script — Langes YouTube-Video (ca. 3:40 Min)

Quelle: docs/content-creator/packages/graham-fair-value-check/VOICEOVER_YOUTUBE_LONG.md

Voiceover-Script — Langes YouTube-Video (ca. 3:40 Min)

Ruhiges, sachliches Tempo. Keine emotionale Steigerung.

(0:00 - 0:20) Intro + Disclaimer

Willkommen.

In diesem Video erklären wir, wie der Benjamin-Graham-Fair-Value-Check bei CAPITAL-AI funktioniert.

Wichtiger Hinweis vorab:

Dies ist keine Anlageberatung. Die gezeigten Informationen stellen ausschließlich quantitative Berechnungen dar. Die endgültige Anlageentscheidung liegt vollumfänglich beim Nutzer.

(0:20 - 1:10) Was ist der Graham Fair Value Check?

Der Fair-Value-Check bei CAPITAL-AI basiert auf den klassischen Prinzipien von Benjamin Graham.

Ziel ist es, einen nachvollziehbaren, mathematischen Wertbereich zu ermitteln – nicht eine Kursprognose.

Das System berechnet auf Basis realer Marktdaten einen Fair-Value-Bereich und stellt diesen dem aktuellen Kurs gegenüber.

Ergänzt wird das Ergebnis durch eine Confidence-Metrik, die Auskunft über die Datenqualität und die Abdeckung der Eingangsgrößen gibt.

Es handelt sich um eine Momentaufnahme auf Grundlage klar definierter Formeln. Keine Simulation. Keine hypothetischen Szenarien.

(1:10 - 2:00) Welche Daten fließen ein?

Für die Berechnung werden mehrere fundamentale Bausteine kombiniert:

Erstens die Earnings Power – also die nachhaltige Ertragskraft eines Unternehmens, abgeleitet aus historischen Gewinnentwicklungen.

Zweitens der Buchwert als bilanzielle Substanzgröße.

Drittens die Sicherheitsmarge – ein zentrales Element der Graham-Logik.

Zusätzlich fließen historische und sektorale Multiplikatoren ein sowie eine Risikoadjustierung auf Basis von Volatilitäts- und Makro-Indikatoren.

Alle Daten stammen aus verifizierten Quellen und werden serverseitig verarbeitet. Es werden keine geschätzten oder künstlich erzeugten Werte verwendet.

(2:00 - 2:50) Wie wird das Ergebnis gelesen?

Das Ergebnis besteht aus drei Elementen:

Erstens einem numerischen Fair-Value-Bereich.

Zweitens der relativen Einordnung des aktuellen Kurses zu diesem Bereich.

Drittens einer Confidence-Metrik.

Liegt der aktuelle Kurs unter dem berechneten Fair-Value-Bereich, ergibt sich nach Graham-Logik eine positive Sicherheitsmarge.

Liegt der Kurs darüber, ist die Marge enger oder negativ.

Wichtig: Diese Einordnung ist rein mathematisch.

Sie stellt keine Empfehlung dar und enthält keine Aussage über zukünftige Kursentwicklungen.

(2:50 - 3:20) Warum dieser Ansatz?

Benjamin Grahams Prinzipien – insbesondere die Sicherheitsmarge und die Orientierung an fundamentaler Substanz – lassen sich gut in transparente, nachvollziehbare Formeln überführen.

CAPITAL-AI automatisiert diesen Prozess und macht ihn konsistent anwendbar.

Der Vorteil liegt in der klaren Herkunft der Daten und der Berechnungslogik.

Jeder Schritt bleibt überprüfbar.

(3:20 - 3:55) Zusammenfassung + erneuter Disclaimer

Zusammengefasst:

Der Graham Fair Value Check bei CAPITAL-AI liefert einen quantitativen Fair-Value-Bereich auf Basis klar definierter fundamentaler Größen und einer Risikoadjustierung.

Das Ergebnis ist eine mathematische Momentaufnahme – keine Prognose und keine Handlungsempfehlung.

Abschließender Hinweis:

Keine Anlageberatung. Die gezeigten Daten stellen ausschließlich quantitative Berechnungen dar. Die endgültige Anlageentscheidung liegt vollumfänglich beim Nutzer.

Technische Hinweise

- Geschätzte Sprechdauer: ca. 3:40 Minuten
- Tempo: ca. 140–150 Wörter/Minute
- Pausen nach Abschnitten: 1–1,5 Sekunden

X - Kompletter Post + Short-Video: Imagine auf X

Quelle: docs/content-creator/packages/graham-fair-value-check/X_IMAGINE_SHORT.md

X - Kompletter Post + Short-Video: Imagine auf X

Ziel: Ein fertiger X-Post mit angehängtem Kurzvideo (ca. 20–30 s) über **Grok Imagine auf X**, inkl. starkem Kraken-Pro-Referral.

1. Kompletter X-Tweet (Copy-Paste)

Grok Imagine auf X: Text → Bild in Sekunden.
Direkt im Feed. Kein Extra-Tool.

So nutze ich es für klare, sachliche Visuals – ohne Hype.

Werbung / Partner:
Tritt Kraken Pro bei – wir können beide Prämien erhalten.
Code yc4ggk3f oder Link:
<https://proinvite.kraken.com/9f1e/xghjfdv4>

#Grok #Imagine #xAI

(Video unten anhängen – siehe Produktionsanweisung)

2. Alternative kürzere Version (wenn Zeichenlimit eng)

Grok Imagine auf X: aus Text wird Bild – direkt im Feed.

Kurz gezeigt im Video

Werbung: Kraken Pro → Code yc4ggk3f
<https://proinvite.kraken.com/9f1e/xghjfdv4>

3. Short-Video (20–30 s) - Storyboard & Script

Zeit	Bild / Aktion	Text-Overlay	Voiceover (optional)
0–3 s	X-Feed / dunkler Clean-Hintergrund, Grok-Icon	„Grok Imagine auf X“	„Imagine auf X – Text wird Bild.“
3–10 s	Tippen eines kurzen Prompts (Beispiel: „clean fintech chart, navy, cyan accents“)	„Prompt eingeben“	„Prompt schreiben – fertig.“
10–18 s	Ergebnisbild erscheint (stilisiertes, abstraktes Fintech-Visual, keine echten Kurse/Ticker)	„Bild in Sekunden“	„Direkt im Feed. Kein Extra-Tool.“

Zeit	Bild / Aktion	Text-Overlay	Voiceover (optional)
18–25 s	Kurzer Cut: noch ein zweites, schlichtes Visual	„Klar. Sachlich. Schnell.“	„Für klare Visuals – ohne Hype.“
25–30 s	Endcard: Logo / dunkler Screen	„Werbung: Kraken Pro · yc4ggk3f“ + Link-Hinweis	Optional weglassen oder nur Text

Format: 1080×1920 (9:16) oder 1:1 für X

Dateiname: `imagine-on-x-short-v1.mp4`

Voiceover (komplett, ~25 s)

„Grok Imagine auf X: aus Text wird Bild – direkt im Feed. Prompt schreiben, fertig. Klar, sachlich, schnell – ohne Hype.“

(Referral nur als Text-Overlay / im Tweet-Text, nicht im Voiceover der Bildungs-/Produkt-Demo, außer Owner will es explizit gesprochen.)

4. Imagine-Prompt für das Demo-Bild im Video

Clean professional fintech visual, dark navy background, subtle cyan geometric lines, abstract data-grid aesthetic, no numbers, no tickers, no logos of real companies, minimal and trustworthy, high contrast, 16:9

Zweites Bild (Variation):

Minimal abstract financial interface mockup, soft gold and cyan accents on deep blue, generous whitespace, no readable text, no charts with real data, elegant and precise, square format

5. Produktions-Checkliste

- ☐ Keine echten Kursdaten, Ticker oder Broker-Logos außer klarer Partner-Kennzeichnung
- ☐ Referral als „Werbung / Partner“ im Tweet-Text kennzeichnen
- ☐ Video-Ende: Code `yc4ggk3f` kurz einblendbar (optional)
- ☐ Tweet + Video zusammen posten
- ☐ Datei hashen und in Publish-Log dokumentieren

6. Referral-Block (Stand)

Tritt Kraken Pro bei, und wir können beide Prämien erhalten.

Verwende meinen Link oder den Referral-Code **yc4ggk3f**:

<https://proinvite.kraken.com/9f1e/xghjfdv4>

X (Twitter) Thread — Copy-Paste

Quelle: docs/content-creator/packages/graham-fair-value-check/X_THREAD.md

X (Twitter) Thread — Copy-Paste

Jedes Tweet einzeln kopieren.

Tweet 1

CAPITAL-AI berechnet einen Fair-Value-Check nach Benjamin-Graham-Prinzipien.
Rein quantitativ. Nachvollziehbar. Ohne Prognose.

Tweet 2

Was fließt ein?

- Earnings Power
- Buchwert
- Sicherheitsmarge
- Historische & sektorale Multiplikatoren
- Risikoadjustierung über Volatilität & Makro-Daten

Tweet 3

Ergebnis = numerischer Fair-Value-Bereich + relative Einordnung zum aktuellen Kurs + Confidence-Metrik.

Tweet 4

Kurs unter dem Fair-Value-Bereich → positive Sicherheitsmarge nach Graham-Logik.
Kurs darüber → engere oder negative Marge.

Tweet 5

Alle Berechnungen laufen serverseitig auf realen Marktdaten.
Keine simulierten Werte. Keine hypothetischen Szenarien.

Tweet 6

Warum dieser Ansatz?
Grahams Prinzipien (Sicherheitsmarge + fundamentale Unterbewertung) lassen sich transparent in Formeln überführen und konsistent anwenden.

Tweet 7

HINWEIS: Keine Anlageberatung. Die gezeigten Daten sind ausschließlich quantitative Berechnungen.
Die Anlageentscheidung liegt vollumfänglich beim Nutzer.

Tweet 8 (Referral - klar als Partner/Werbung)

Werbung / Partner:

Tritt Kraken Pro bei, und wir können beide Prämien erhalten.

Link oder Code yc4ggk3f:

<https://proinvite.kraken.com/9f1e/xghjfdv4>

SEO D3 — Soft-404 Behoben

Quelle: docs/seo/D3_SOFT_404.md

SEO D3 — Soft-404 Behoben

Status: **VERIFIED in production** (PR #360 merged; deploy commit 54c48ca)

Roadmap: SEO-GM-ROADMAP-0002 / WP-D3

Evidence: docs/evidence/seo/D3_SOFT_404_PROD_GAP_2026-08-16.md

Verhalten (Soll / live)

In **Produktion** (NODE_ENV=production):

Pfad	Antwort
/ , /impressum , /agb , /datenschutz	200 + passendes HTML (SPA/prerender shell)
unbekannte Pfade (z.B. /foo-bar-xyz)	404 Not Found (text/plain , kein SPA-Shell)
Scanner-Köder (.php , /wp-admin , ...)	404 (via PROBE_PATH_PATTERNS)
echte Static-Assets unter /assets/...	200 via express.static

In **Development** bleibt Vite-Middleware unverändert.

Technik

- registerProductionSpaFallback(app, distPath) — kanonischer Production-Catch-all (Allow-List, fail-closed 404).
- express.static(distPath, { redirect: false, index: false }) — kein Directory-Trailing-Slash-Redirect (Konflikt mit Q2 + S2-Prerender-Ordnern).
- installProductionSoft404Intercept() bleibt als optionaler Defense-in-Depth-Patch, ist aber **nicht** die Production-Source-of-Truth (unzuverlässig unter esbuild-Bundle / dual express instance).

Produktions-Verifikation (2026-08-16T00:40Z)

Deploy-Header: x-capital-ai-commit: 54c48ca28817b41b93623be61ea8292f0a8288c2 ,
x-capital-ai-branch: main .

URL	Observed
https://capital-ai.online/	200
https://capital-ai.online/impressum	200
https://capital-ai.online/impressum/	301 → /impressum (Q2)
https://capital-ai.online/agb	200
https://capital-ai.online/datenschutz	200

URL	Observed
https://capital-ai.online/not-a-real-page-xyz-seo-check	404 text/plain body Not Found
https://capital-ai.online/wp-admin	404

```
curl -s -o /dev/null -w "%{http_code}" https://capital-ai.online/impressum # 200
curl -s -o /dev/null -w "%{http_code}" https://capital-ai.online/not-a-real-page-xyz-seo-check # 404
```

Unit: tests/unit/soft404Intercept.test.ts

Contract: tests/server/seoApplicationWiring.contract.test.ts

SEO Block D (+ Q2 completion) — Implementation Notes

Quelle: docs/seo/D_BLOCK_IMPLEMENTATION_NOTES.md

SEO Block D (+ Q2 completion) — Implementation Notes

Roadmap: SEO-GM-ROADMAP-0002
Branch (prod Soft-404 fix): seo/wp-d3-soft-404-prod-fix-2026-08-16

Wiring status (2026-08-16)

ID	Status	How
Q2 Trailing-Slash 301	LIVE	<code>registerTrailingSlashNormalize(app)</code> in <code>server/routes/registerApplicationRoutes.ts</code>
D3 Soft-404	CODE FIX (this PR)	<code>registerProductionSpaFallback + express.static(..., { redirect: false, index: false })</code> in composition root; evidence of prior prod gap documented

Apply / re-apply D3 soft-404 (idempotent)

```
node scripts/seo/apply-server-wiring.mjs
git add server.application.ts && git commit -m "seo(D3): wire registerProductionSpaFallback + static redirect:false"
```

Target production branch in `startServer()`

```
import { registerProductionSpaFallback } from './server/runtime/spaFallback';
// ...
} else {
  const distPath = path.join(process.cwd(), 'dist');
  app.use(express.static(distPath, { redirect: false, index: false }));
  registerProductionSpaFallback(app, distPath);
}
```

`installProductionSoft404Intercept()` remains as defense-in-depth only; it is **not** the production source of truth under the esbuild bundle (dual express instance).

Evidence

- docs/evidence/seo/D3_SOFT_404_PROD_GAP_2026-08-16.md
- docs/seo/D3_SOFT_404.md

Other D-block artefacts

- D1 JSON-LD, D2 routeSeo, D4 vite chunks, D5 GSC runbook

- S1 SeoEngine (VERIFIED)

Übergabe — WP-S1 SeoEngine an nächsten Bearbeiter (Grok)

Quelle: docs/seo/HANDOFF_WP_S1_NEXT_2026-08-15.md

Übergabe — WP-S1 SeoEngine an nächsten Bearbeiter (Grok)

Von: Claude (Sonnet 5 / Opus 5, Sessions 2026-08-15)
An: Grok — übernimmt SEO-GM-ROADMAP-0002 / WP-S1 und die anschließenden SEO-Code-WPs
Stand: 2026-08-16 — WP-S1 **VERIFIED** (ADR-0082 nummeriert)
Repo-Kontext: Multi-Agent-Koordination über `.ai/work-claims/*.json`, `docs/coordination/claims/*.md` und Roadmap-Statustabellen.

1. Kurzfassung

WP-S1 (SeoEngine Persistenz, RLS, No-Demo-Data) ist **VERIFIED**. Code liegt auf `main` (PR #335), alle fünf Supabase-Migrationen sind auf Produktion angewendet und verifiziert, ADR ist **ADR-0082**. Nächstes Code-WP laut Roadmap §10: **WP-D1/D2/D3** (JSON-LD, Title/Meta, Soft-404).

2. Was erledigt ist — mit Belegen

2.1 Code (main, PR #335)

Baustein	Pfad
Domain-Typen + Service-Fassade	<code>src/platform/SeoEngine/</code>
Store-Abstraktion	<code>src/platform/SeoEngine/store/</code>
Admin-API	<code>server/routes/seoEngineRoutes.ts</code> → <code>/api/seo/*</code>
Tests	<code>tests/unit/seoEngineStore.test.ts</code> , <code>seoEnginePersistence.contract.test.ts</code> , <code>seoEngine.test.ts</code>
Dashboard	S3, PR #309

2.2 Datenbank (Supabase AIFINANCIAL)

Vier Migrationen + Ledger-Abgleich angewendet (Owner-Freigabe 2026-08-15). FK `seo_rank_snapshots.keyword_id` = **ON DELETE RESTRICT**. Details: `docs/runbooks/SEO_WP_S1_LEDGER_RECONCILIATION.md`.

2.3 ADR

Draft	Canonical
docs/adr/ADR-DRAFT-seo-engine-platform-module.md (SUPERSEDED redirect)	docs/adr/ADR-0082-seo-engine-platform-module.md

Kollisionscheck 2026-08-16 nach PR #345 (0075-0081 belegt) → **ADR-0082**.

3. Branch-/PR-Zustand (historisch)

- PR #333 Grants, #335 Store, #338 Docs-Closure, #341 Follow-up — merged
- Claim `SEO-WP-S1-ADR-0082-2026-08-16` — ADR-Nummerierung + VERIFIED-Status

4. Nächster Schritt: WP-D1 / D2 / D3

Neuen Branch + Work Claim anlegen. Scope:

- D1 JSON-LD Organization/Website/SoftwareApplication
- D2 Routen-spezifische Title/Meta
- D3 Soft-404 (siehe `docs/seo/D3_SOFT_404.md`, `docs/seo/D_BLOCK_IMPLEMENTATION_NOTES.md`)

Kein Shared-Zone-Lease nötig, wenn nur öffentliche SEO-Frontend-/SPA-Wiring-Pfade betroffen sind — trotzdem Scope eng halten.

5. Roadmap §10 (Stand nach ADR-0082)

1. ~~FK RESTRICT + Ledger~~ — erledigt
2. Search Console Property verifizieren (WP-Q-CLOSE / Q3) — Owner-Aktion
3. ~~ADR-Nummerierung~~ — **ADR-0082**, WP-S1 VERIFIED
4. ADR-0068 + ESS-0022 Owner-Review (WP-M0) — ohne Runtime
5. **WP-D1 / D2 / D3** — nächstes Code-WP
6. WP-S2 erst nach formalem Prerender-ADR

6. Guardrails

- **No-Demo-Data:** keine Seed-/estimated-Ranks
- **Privilege:** `service_role` -only, deny-by-default RLS
- **seo_rank_snapshots** : kein DELETE/TRUNCATE für `service_role`
- **Shared-Zone-Lease:** keine globalen Auth-/Billing-/Deploy-Dateien im SEO-PR

7. Referenzen

Zweck	Pfad
WP-S1 Status	<code>docs/seo/S1_SEO_ENGINE.md</code>
DoD / Implementierung	

Zweck	Pfad
	docs/seo/WP_S1_PERSIS-TENCE_IMPLEMENTATION.md
ADR	docs/adr/ADR-0082-seo-engine-platform-module.md
Roadmap	docs/roadmaps/SEO_G00-GLE_MARKETING_CONSOLIDATED_ROADMAP.md

SEO N4 — Content-Freigabe vor Publish

Quelle: docs/seo/N4_CONTENT_APPROVAL.md

SEO N4 — Content-Freigabe vor Publish

Status: implementiert (API + In-Memory)

Roadmap: SEO-ROADMAP-0001 / N4

Gate

publishType	Gate
draft	nein
scheduled	nein (Eintrag nur Log)
instant (oder fehlend)	ja, wenn isApprovalGateEnabled()

Aktivierung: - Production: **an** (Default) - SOCIAL_MEDIA_REQUIRE_APPROVAL=false → aus - SOCIAL_MEDIA_REQUIRE_APPROVAL=true → an (auch Dev)

API

Method	Path	Zweck
POST	/api/social-media/approvals	Freigabeantrag anlegen (pending)
GET	/api/social-media/approvals	Liste (optional ?status=)
POST	/api/social-media/approvals/:id/approve	freigeben
POST	/api/social-media/approvals/:id/reject	ablehnen
POST	/api/social-media/publish	Instant braucht approvalId (approved → consumed)

Ablauf

1. POST /generate → Textpaket
2. POST /approvals mit Titel + Kurzsummary
3. Owner approve
4. POST /publish mit approvalId + publishType: instant

Kein Auto-Publish. Kein Reuse derselben Approval-ID.

Persistenz

Migration-Draft: `supabase/migrations/20260815140000_social_media_content_approvals.sql`

Laufzeit: In-Memory bis Apply + Store-Kopplung.

SEO Q3 — Google Search Console Property verifizieren

Quelle: docs/seo/Q3_SEARCH_CONSOLE_VERIFY_RUNBOOK.md

SEO Q3 — Google Search Console Property verifizieren

Roadmap: SEO-GM-ROADMAP-0002 / WP-Q-CLOSE / Q3
Status: **VERIFIED** (2026-08-16)
Claim: `.ai/work-claims/SEO-WP-Q3-SEARCH-CONSOLE-VERIFY-2026-08-16.json`
Nachfolger: D5 Search Console MCP Read (`docs/seo/SEARCH_CONSOLE_MCP_RUNBOOK.md`)

Verifizierungsergebnis (Owner, 2026-08-16)

Prüfpunkt	Status
Property-Typ	Domain <code>capital-ai.online</code>
Eigentum / Ownership	Bestätigt (Owner)
<code>https://capital-ai.online/sitemap.xml</code> in GSC	Erfolg / grün
Falsche Seiten-URLs als Sitemap	vom Owner entfernt
<code>robots.txt</code> / live Sitemap	200 (4 öffentliche URLs)
Soft-404	VERIFIED (PR #360)

Abnahme-DoD (Q3) — erfüllt

- [x] Property `capital-ai.online` (Domain) zeigt Status **Bestätigt**.
- [x] Sitemap in GSC eingereicht und ohne harten Fehler (Success).
- [x] Evidence + Claim `verified` (dieser Branch / PR).

Bereits erfüllt (technisch)

Prüfpunkt	Status
<code>https://capital-ai.online/robots.txt</code>	200 , Sitemap-Zeile vorhanden
<code>https://capital-ai.online/sitemap.xml</code>	200 , <code>application/xml</code> , 4 öffentliche URLs
Canonical in <code>index.html</code>	<code>https://capital-ai.online/</code>
Soft-404	VERIFIED (PR #360)
Meta-Placeholder Q3 in <code>index.html</code>	Kommentar vorhanden; kein Token nötig (DNS/Do-main-Verify)

Methode (ausgeführt)

Domain-Property `capital-ai.online` — Ownership bereits bestätigt. Sitemap `https://capital-ai.online/sitemap.xml` eingereicht und erfolgreich.

Nach Verifizierung

Aktion	Wer	Status
Sitemap submit	Owner in GSC UI	DONE
Claim + Roadmap Q3 → VERIFIED	Agent	dieser PR
D5 MCP Read-Credentials	Owner separat (SEA - RCH_CONSOLE_MCP_RUNBOOK.md)	nicht Teil von Q3

Nicht tun (unverändert)

- Keine GSC-Service-Account-Keys oder OAuth-Secrets ins Repository.
- Kein Write-Scope für MCP (ESS-0014).
- Keine zweite parallele Verify-Methode „auf Vorrat“ committen.

SEO Block Q — Implementation Notes

(2026-08-15)

Quelle: docs/seo/Q_BLOCK_IMPLEMENTATION_NOTES.md

SEO Block Q — Implementation Notes (2026-08-15)

Roadmap: docs/seo/SEO_MANAGEMENT_ROADMAP.md (SEO-ROADMAP-0001)

Branch: seo/q-quick-wins-foundation

Claim: SEO-Q-QUICK-WINS-2026-08-15

Delivered

ID	Status	Artefakt
Q1	done	public/robots.txt , public/sitemap.xml
Q2	partial	index.html → <link rel="canonical" href="https://capital-ai.online/"> ; noscript-Links ohne trailing slash. Serverseitige Trailing-Slash-Redirects → Follow-up (D/S).
Q3	owner action	Kommentar-Platzhalter in index.html . Owner muss Search-Console-Property anlegen und Meta- oder DNS-Token setzen.
Q4	done	docs/seo/SEO_CHECKLIST.md aktualisiert
Q5	done	public/og-image.svg ; og:image + twitter:image → https://capital-ai.online/og-image.svg
Q6	N/A	Keine aistudio / AI-Studio-CORS-Ausnahme im aktuellen Repository-Tree gefunden. Keine Code-Änderung.

Owner follow-ups

- Search Console:** Property capital-ai.online verifizieren (Meta-Tag in index.html oder DNS-TXT).
- Sitemap submit:** Nach Deploy Sitemap in Search Console einreichen.
- OG PNG (optional):** Viele Plattformen bevorzugen PNG/JPG 1200×630; SVG ist first-party und korrekt, aber nicht universell.

4. **Trailing-Slash-Middleware:** 301 von `/datenschutz/` → `/datenschutz` (und analog) serverseitig in Block D.

Out of scope (next blocks)

- JSON-LD (D1), route-specific titles (D2), soft-404 (D3), bundle split (D4), GSC MCP (D5)
- SeoEngine (S1), prerender (S2)

SEO S1 / WP-S1 — SeoEngine Foundation & Persistenz

Quelle: docs/seo/S1_SEO_ENGINE.md

SEO S1 / WP-S1 — SeoEngine Foundation & Persistenz

Status: Foundation + Store-Code **auf main** (PR #335); Schema + Grants + FK RESTRICT + Ledger **vollständig auf Produktion angewendet**; ADR **ADR-0082** nummeriert — **WP-S1 VERIFIED**

Roadmap: SEO-GM-ROADMAP-0002 / WP-S1

Claims: SEO-WP-S1-PERSISTENCE-2026-08-15 → SEO-WP-S1-STORE-CODE-2026-08-15 (merged) → SEO-WP-S1-FOLLOWUP-HARDENING-2026-08-15 (applied) → SEO-WP-S1-ADR-0082-2026-08-16

Prep-Doc: docs/seo/WP_S1_PERSISTENCE_IMPLEMENTATION.md

ADR: docs/adr/ADR-0082-seo-engine-platform-module.md

Handoff: docs/seo/HANDOFF_WP_S1_NEXT_2026-08-15.md

Geliefert

Baustein	Pfad	Evidence
Types + Service-Facade	src/platform/SeoEngine/	main
Store-Abstraktion	src/platform/SeoEngine/store/ (ISeoEngineStore , Memory, Supabase)	PR #335
Admin API	server/routes/seoEngineRoutes.ts → /api/seo/*	Store + 503 fail-closed
Schema Foundation	supabase/migrations/20260815010000_seo_engine.sql	Prod applied
Source-Align + RLS Harden	supabase/migrations/20260815200000_seo_engine_source_align_rls.sql	Prod applied
service_role Grants	supabase/migrations/20260815210000_seo_engine_service_role_grants.sql	PR #333 + Prod applied
FK RESTRICT	supabase/migrations/20260815220000_seo_rank_snapshots_fk_restrict.sql	Prod applied 2026-08-15
Ledger-Abgleich	docs/runbooks/SEO_WP_S1_LEDGER_RECONCILIATION.md	Ausgeführt 2026-08-15
ADR	docs/adr/ADR-0082-seo-engine-platform-module.md	Accepted 2026-08-16
Tests (memory + contracts)	tests/unit/seoEngineStore.test.ts , seoEnginePersistence.contract.test.ts	main
Dashboard	S3 / PR #309	main

No-Demo-Data

Ranks starten leer. API akzeptiert nur `search-console` | `manual-import` (kein `estimated`).

WP-S1 DoD-Status

1. ~~ `ISeoEngineStore` + Supabase-Adapter (`getServerSupabase`)~~ — **main** (PR #335)
2. ~~Production fail-closed ohne privileged Supabase~~ — Factory + 503 in Routes
3. ~~Migration Production-Apply: Foundation / Source-Align / Grants / FK RESTRICT / Ledger-Abgleich~~ — **alle fünf angewendet** (Evidenz: `docs/runbooks/SEO_WP_S1_LEDGER_RECONCILIATION.md`)
4. ~~Contract-Tests für Source-Reject und leere Rank-Liste~~ — main
5. ~~ADR nummeriert~~ — **ADR-0082** (Kollisionscheck nach PR #345: 0075-0081 belegt; nächste freie Nummer 0082)

WP-S1 = VERIFIED. Nächstes Code-WP laut Roadmap §10: **WP-D1 / D2 / D3.**

Siehe Implementierungsplan: `WP_S1_PERSISTENCE_IMPLEMENTATION.md` , Übergabe: `HAN-DOFF_WP_S1_NEXT_2026-08-15.md` .

SEO S2 — Public Route Prerender

Quelle: docs/seo/S2_PRERENDER.md

SEO S2 — Public Route Prerender

Status: Build-wired

Roadmap: SEO-ROADMAP-0001 / S2

Verhalten

1. Nach `vite build` schreibt `scripts/seo/prerender-public-routes.mjs`: - `dist/index.html` (aktualisierte Meta) - `dist/impressum/index.html` - `dist/agb/index.html` - `dist/datenschutz/index.html`
2. Pro Route: `<title>`, description, canonical, Open Graph, Twitter, noscript-Haupttext.
3. Produktion: `resolvePublicHtmlFile` liefert die route-spezifische Datei, falls vorhanden.

Scripts

```
npm run build           # enthält prerender
npm run seo:prerender   # nur Prerender (dist muss existieren)
```

Grenzen

- Kein vollständiges React-SSR: der SPA-Body kommt weiter per JS.
- Noscript liefert bewusst nur Kurztext (keine erfundenen Rechtstexte).
- Nächster Ausbau: shared Legal-Copy-Module → echtes HTML im noscript/body.

SEO S3 — Management Dashboard

Quelle: docs/seo/S3_SEO_DASHBOARD.md

SEO S3 — Management Dashboard

Roadmap: SEO-ROADMAP-0001 / S3

Status: abgeschlossen — gemergt mit PR #309

Zugriff: Owner/Admin; Backend-Endpunkte bleiben durch `checkAdminAccess` geschützt.

Geliefert

- neuer Admin-Tab „SEO Management“
- KPI-Karten für Keywords, Rankings und Content-Inventar
- Keyword- und Content-Tabellen
- Quellenstatus für Search Console, GA4 und manuelle Importe
- defensiv validierte API-Antworten
- ehrliche Leerstatistiken statt Demo-, Mock- oder Schätzwerten
- Tests für ungültige Payloads und Quellenstatus

Datenquellen

Das Dashboard liest ausschließlich `/api/seo/summary`, `/keywords`, `/ranks` und `/content`. Search Console gilt nur dann als verbunden, wenn ein Rank-Snapshot diese Quelle ausweist. GA4 bleibt „nicht verbunden“, bis ein produktiver, autorisierter Datenadapter bereitsteht.

Bewusste Grenzen

- keine externe Google-, Supabase- oder Render-Mutation
- keine Credentials im Frontend
- keine künstlichen Rankings
- S1 verwendet weiterhin den vorhandenen In-Memory-Store; Persistenz-Wiring bleibt separat

SEO S4 — Sprach- und hreflang-Strategie

Quelle: docs/seo/S4_LANGUAGE_AND_HREFLANG_STRATEGY.md

SEO S4 — Sprach- und hreflang-Strategie

Roadmap: SEO-ROADMAP-0001 / S4

Status: abgeschlossen

Baseline: main@ac47dfd901155c56c61f733bc7e8df9e892341ff

Entscheidung

CAPITAL-AI bleibt bis zur Bereitstellung vollständig übersetzter, eigenständig adressierbarer Sprachvarianten **German-first**:

- Dokument- und Inhaltssprache: Deutsch
- HTML-Sprachdeklaration: `lang="de"`
- strukturierte Daten: `inLanguage: "de-DE"`
- Open Graph Locale: `de_DE`
- bestehende kanonische URLs bleiben sprachneutral und zeigen auf die deutsche Fassung
- Keywords dürfen Produkt- oder Fachbegriffe auf Englisch enthalten, werden aber als deutschsprachige Suchintention verwaltet

hreflang-Regel

Aktuell werden **keine** hreflang-Links ausgegeben. Es existieren keine gleichwertigen, kanonischen Übersetzungs-URLs. Selbstreferenzielle oder erfundene Alternativen würden Suchmaschinen eine nicht vorhandene Internationalisierung signalisieren.

hreflang wird erst aktiviert, wenn für jede freigegebene Sprache:

1. eine stabile URL-Struktur beschlossen ist, beispielsweise `/de/...` und `/en/...`;
2. Titel, Meta Description, sichtbarer Hauptinhalt und rechtliche Texte vollständig übersetzt sind;
3. jede Sprachseite einen Self-Canonical besitzt;
4. alle Varianten wechselseitig aufeinander verweisen;
5. `x-default` auf eine bewusst gewählte Default- oder Sprachauswahlseite zeigt;
6. Sitemap, Prerender-Ausgabe und Tests dieselben Sprachbeziehungen enthalten.

Keyword-Strategie

- Locale im SeoEngine-Kkeyword-Register bleibt ein Pflichtmerkmal.
- Deutsche Inhalte verwenden `de-DE`.

- Englische Finanz- und Technikbegriffe dürfen Bestandteil deutscher Keyword-Phrasen sein.
- Ein Keyword erhält erst dann `en-*`, wenn sein Zielpfad tatsächlich englischen Inhalt liefert.
- Ranking-Daten verschiedener Locales werden nicht zusammengeführt.

Akzeptanznachweis

- `index.html` enthält `lang="de"`.
- JSON-LD weist die Website mit `de-DE` aus.
- Open Graph verwendet `de_DE`.
- Im Repository existiert kein produktives `hreflang`.
- Es existieren keine kanonischen englischen Inhaltsrouten.
- Kein externer Dienst und keine Produktionskonfiguration wurde verändert.

Folgepunkt

Bei Beginn von Roadmap J3 muss diese Strategie durch einen eigenen Internationalisierungs-ADR ersetzt oder erweitert werden. Erst dieser Schritt darf URL-Schema, Locale-Fallback, Übersetzungs-Governance und produktive `hreflang`-Ausgabe festlegen.

Search Console MCP — Runbook (D5)

Quelle: docs/seo/SEARCH_CONSOLE_MCP_RUNBOOK.md

Search Console MCP — Runbook (D5)

Status: spezifiziert, Read-Plane noch nicht produktiv

Bezug: docs/architecture/CAPITAL_AI_GOOGLE_MARKETING_MCP_TOPOLOGY.md , SEO-ROADMAP-0001 D5

Ziel

Zweiter MCP-Read-Server neben `ga4-analytics` , strikt **lesend**, für Indexierungs- und Query-Reports.

Voraussetzungen (Owner)

1. Google Search Console Property für `capital-ai.online` verifiziert (Q3).
2. Google Cloud Projekt mit Search Console API aktiviert.
3. Service-Account oder OAuth-Client mit **read-only** Zugriff auf die Property.
4. Credentials **nicht** im Repository — analog zu GA4 unter `~/.capital-ai/` oder Secret-Store.

Empfohlener `.mcp.json` -Eintrag (nach Credential-Bereitstellung)

```
"search-console": {
  "command": "npx",
  "args": ["-y", "@modelcontextprotocol/server-google-search-console"],
  "env": {
    "GOOGLE_APPLICATION_CREDENTIALS": "${HOME}/.capital-ai/gsc-mcp-credentials.json"
  }
}
```

Paketname und Env-Variablen vor Produktivschaltung gegen die aktuelle MCP-Server-Dokumentation prüfen. Nur Read-Scopes.

Governance

- Keine Write-Capabilities (ESS-0014).
- Consent-/Marketing-Tags bleiben unberührt (Ebene ①/② der Topologie).
- Vor Aktivierung: Eintrag in `DATENSCHUTZ_PROTOKOLL.md` und Owner-Freigabe.

SEO Checklist & Technical Discovery Guide

Quelle: docs/seo/SEO_CHECKLIST.md

SEO Checklist & Technical Discovery Guide

Project: CAPITAL-AI

Stand: 16.08.2026 — WP-D3 Soft-404 VERIFIED; **Q3 Search Console Domain property VERIFIED; WP-D1/D2 VERIFIED** (PR #375 + Owner Rich Results Test)

Umsetzungsplan: docs/roadmaps/SEO_GOOGLE_MARKETING_CONSOLIDATED_ROADMAP.md (SEO-GM-ROADMAP-0002)

1. Crawling & Indexierung

- [x] robots.txt / sitemap.xml — **Q1** (live 200)
- [x] canonical + Trailing-Slash 301 — **Q2** (canonical + server 301 live; WP-Q-CLOSE rest: GSC)
- [x] Search-Console-Verifizierung — **Q3 VERIFIED** (Domain capital-ai.online, Ownership bestätigt, Sitemap success) → docs/seo/Q3_SEARCH_CONSOLE_VERIFY_RUNBOOK.md
- [x] Echte 404 (Soft-404 behoben) — **D3** (PR #360, prod VERIFIED)

3. JSON-LD / Meta

- [x] JSON-LD Organization/WebSite/SoftwareApplication — **D1 VERIFIED** (PR #375; ImageObject logo + offers/image; Owner Rich Results Test 2026-08-16)
- [x] Routen-Titles client-side — **D2 VERIFIED** (routeSeo + main.tsx load/popstate; pre-render; unique titles live on /, /impressum, /agb, /datenschutz)
- [x] og:image first-party — **Q5**

4. Crawler-Render

- [] Prerender Meta + noscript pro Public-Route — **S2** (ADR formal noch offen; script live)
- [] Full React-Body SSR — optional Follow-up

5. Performance

- [] manualChunks / CWV — **D4** (carried)

6. Management & Content

- [] Search Console MCP Credentials — **D5** (nach Q3; SEARCH_CONSOLE_MCP_RUNBOOK.md)
- [x] SeoEngine foundation — **S1 VERIFIED** (ADR-0082)
- [] Generate text/scripts — **N1/N2**
- [] Owner-Freigabe vor Instant-Publish — **N4**
- [] Media-Rendering — **N3** (Make-or-Buy)

S3 Management Dashboard

- [x] Owner/Admin-Dashboard für SeoEngine-KPIs — **S3**

S4 Sprache und hreflang

- [x] German-first-Strategie dokumentiert — **S4**
- [x] Kein irreführendes `hreflang` ohne kanonische Übersetzungs-URLs

CAPITAL-AI SEO Management — Programm-Roadmap

Quelle: docs/seo/SEO_MANAGEMENT_ROADMAP.md

CAPITAL-AI SEO Management — Programm-Roadmap

Status: SUPERSEDED (2026-08-15)

Nachfolger (Single Point of Trust): [docs/roadmaps/SEO_G00-](#)

[GLE_MARKETING_CONSOLIDATED_ROADMAP.md](#) — **Document ID: SEO-GM-ROADMAP-0002**

Dieses Dokument behält historischen Evidence-Wert. Es begründet **keine** parallele Programmautorität mehr. Offene Arbeitspakete und Statusfortschreibung erfolgen ausschließlich über SEO-GM-ROADMAP-0002.

Document ID

SEO-ROADMAP-0001 (superseded)

Bezug

- [docs/seo/SEO_CHECKLIST.md](#)
- [docs/architecture/CAPITAL_AI_GOOGLE_MARKETING_MCP_TOPOLOGY.md](#)
- [docs/architecture/CAPITAL_AI_ARCHITEKTUR_BEWERTUNGSMATRIX_2026-08-08.md](#)
- [docs/adr/ADR-0026-social-media-direct-publishing-real-integration.md](#) (dort als ADR-0020 zitiert)
- [docs/adr/ADR-0027-social-media-access-restriction-owner-founder.md](#)
- [docs/architecture/ENTERPRISE_FINTECH_SCREENING_GOVERNANCE_AUDIT.md](#) (Formatvorlage, §10)
- **Kanonisch ab 2026-08-15:** [docs/roadmaps/SEO_GOOGLE_MARKETING_CONSOLIDATED_ROADMAP.md](#)

Status

SUPERSEDED — ehemals Aktiv. Fortschritt und offene Pakete sind in SEO-GM-ROADMAP-0002 konsolidiert (Stand 2026-08-15).

Historischer Inhalt (unverändert, nur Evidence)

Der nachfolgende Text bleibt als historische Spezifikation erhalten und wird nicht fortgeschrieben.

1. Zielbild

Ziel. Ein vollständiges Capital-AI SEO Management aufbauen.

Vision. Über das AI SEO Management wird automatisiert ein **autonomes Marketing** integriert.

Mission. Anbindung aller relevanten Social-Media-Plattformen über Supabase sowie API-Konfiguration über den Google-Admin-Connector des Google MCP. Innerhalb der Webanwendung entstehen aus vordefinierten Skripten Podcasts, Tweets, Community-Beiträge, Videos, Lernvideos und weitere Werbemittel, die direkt auf die Plattformen gestellt werden.

Wesentliche Vorbedingung. Ziel, Vision und Mission bauen aufeinander auf: ohne messbares SEO (Blöcke `Q - D`) gibt es keine Steuergröße; ohne SEO-Management-Kern (`S`) keine Automatisierung; ohne Content-Generierung (`N`) keine Mission; ohne Feedback-Loop (`H`) keine Autonomie (`J`).

2. Legende der Zeithorizont-Präfixe

Die Präfixe folgen der in ARCH-AUDIT-0002 (§14) und ARCH-AUDIT-0005 (§10) etablierten Konvention. Es sind **deutsche Zahlwort-Anfangsbuchstaben** für den jeweiligen Zeithorizont; lediglich die Sofortmaßnahmen tragen das englische Kürzel:

Präfix	Zeithorizont	Herleitung
Q	Quick Wins (< 1 Woche, je ≤ 2 PT)	Quick Wins
D	30 Tage	Dreißig
S	60 Tage	Sechzig
N	90 Tage	Neunzig
H	180 Tage	Hundertachtzig
J	12 Monate	Jahr

Nicht zu verwechseln mit `P0 - P3` (Priorität) und `AUD<n>-F-<nnn>` (Befund-IDs aus Audit n).

3. Ausgangslage (verifiziert, Stand `1809f03`)

3.1 SEO — faktisch nicht vorhanden

Befund	Nachweis
Kein <code>robots.txt</code> , keine <code>sitemap.xml</code>	nicht im Repository; <code>public/</code> enthält nur <code>.well-known/</code> , <code>cookiehub-init.js</code> , <code>favicon.svg</code> , <code>google-analytics-consent.js</code> , Security-/TikTok-Nachweise
Kein JSON-LD / <code>schema.org</code>	<code>index.html</code> ohne <code>application/ld+json</code>
Kein <code>canonical</code> , keine Search-Console-Verifizierung	<code>index.html</code> — Duplicate-Content-Risiko, da <code>/datenschutz</code> und <code>/datenschutz/</code> bedient werden

Befund	Nachweis
Alle Routen teilen einen <code><title></code>	SPA mit einer <code>index.html ; /impressum , /agb , / datenschutz</code> rendern identisch „CAPITAL-AI Portal“
Kein SSR/Prerendering	SPA-Fallback liefert <code>dist/index.html</code> ; Crawler sehen ein leeres <code><div id="root"></code>
Soft-404	nur Scanner-Köderpfade liefern 404 (<code>PRO-BE_PATH_PATTERNS</code>); jede andere unbekannte URL antwortet HTTP 200
Ein Bundle, 2,49 MB / 678 kB gzip	<code>vite build</code> ; deckt sich mit <code>D3</code> aus ARCH-AU-DIT-0005 → hier als <code>carried</code> geführt
<code>og:image</code> auf Fremd-Domain	<code>index.html</code> : <code>https://webscan-radar.com/badge/Capital-AI.online</code>

3.2 Social Publishing — echt gebaut, endet vor der Mission

Vorhanden und funktionsfähig: PKCE-OAuth, verschlüsselter Token-Store, Publish-Log, Zugriffsbeschränkung auf Owner/Founder (ADR-0027), Supabase-Migration

`20260801150000_social_media_publishing.sql` , Routen und UI.

Plattform	Heutiger Zustand
X (Text-Tweet)	veröffentlicht real
Facebook (Page-Text-Post)	veröffentlicht real
YouTube, TikTok, Instagram	scheitern bewusst mit <code>mediaRequiredError</code> — es existiert kein Rendering
LinkedIn, Reddit, Discord, Telegram, Podcast-RSS	nicht angebunden

Die Content-Generierung fehlt vollständig: `SocialMediaGeneratorService.ts` dokumentiert selbst, dass `generateSeries` , der Endpunkt `POST /api/social-media/generate` und die Studio-Oberfläche nie geliefert wurden. **Genau hier setzt Block N an.**

3.3 Google MCP

`.mcp.json` bindet einen einzigen Read-Server ein (`ga4-analytics`). Search Console, Ads, AdSense sowie der gesamte Write-/Admin-Pfad sind spezifiziert, aber nicht implementiert — siehe `CAPITAL_AI_GOOGLE_MARKETING_MCP_TOPOLOGY.md` .

4-8. Historische Priorisierung, Lieferschnitt, ADRs, Risiken

Siehe Originalversion vor SUPERSEDED-Markierung bzw. die konsolidierte Fortschreibung in **SEO-GM-ROADMAP-0002** (aktueller Ist-Stand Q/S3/S1 und Work-Package-Mapping).

WP-S1 — SeoEngine Persistenz: Implementierungsplan & Status

Quelle: docs/seo/wp_s1_persistence_implementation.md

WP-S1 — SeoEngine Persistenz: Implementierungsplan & Status

Roadmap: SEO-GM-ROADMAP-0002 / WP-S1

Claims: SEO-WP-S1-PERSISTENCE-2026-08-15 → SEO-WP-S1-STORE-CODE-2026-08-15 → SEO-WP-S1-FOLLOWUP-HARDENING-2026-08-15 → SEO-WP-S1-ADR-0082-2026-08-16

Store-Code Branch (merged): seo/wp-s1-store-adapters → PR #335

Status: Store-Code **DELIVERED on main**; Schema Foundation/Grants/FK RESTRICT/Ledger-Abgleich **applied** (Owner, 2026-08-15); ADR **ADR-0082 Accepted** — **WP-S1 VERIFIED**

Stand: 2026-08-16

1. Ziel

SeoEngine von rein in-memory auf **persistente** Keyword-/Rank-/Content-Daten umstellen, ohne No-Demo-Data oder Admin-IAM zu verwässern.

Anforderung	Soll	Ist
Rank-Quellen	nur search-console manual-import	API + SQL CHECK + Tests
Leerzustand	ehrlich (keine Seed-Ranks)	
Schreibpfad	Server privileged Supabase	SupabaseSeoEngineStore
RLS	deny-by-default; kein Public Write	enable + revoke anon/auth
API	/api/seo/* admin-gated	+ Store + 503
Fallback	Memory nur Dev/Test; Prod fail-closed	Factory
ADR	nummeriert, Accepted	ADR-0082

2. Ist-Zustand (verifiziert, nach PR #333 / #335 / #341 / ADR-0082)

Baustein	Status
ISeoEngineStore + Memory + Supabase	main (PR #335)
Admin-Router /api/seo auf Store	
Dashboard S3	PR #309

Baustein	Status
Migration Foundation 20260815010000	Repo + Prod apply
Source-Align 20260815200000	Repo + Prod apply
service_role Grants 20260815210000	Repo + Prod apply (PR #333)
FK RESTRICT 20260815220000	Repo + Prod apply 2026-08-15
Ledger-Abgleich (schema_migrations)	ausgeführt 2026-08-15
ADR formalisiert/nummeriert	ADR-0082 (2026-08-16)

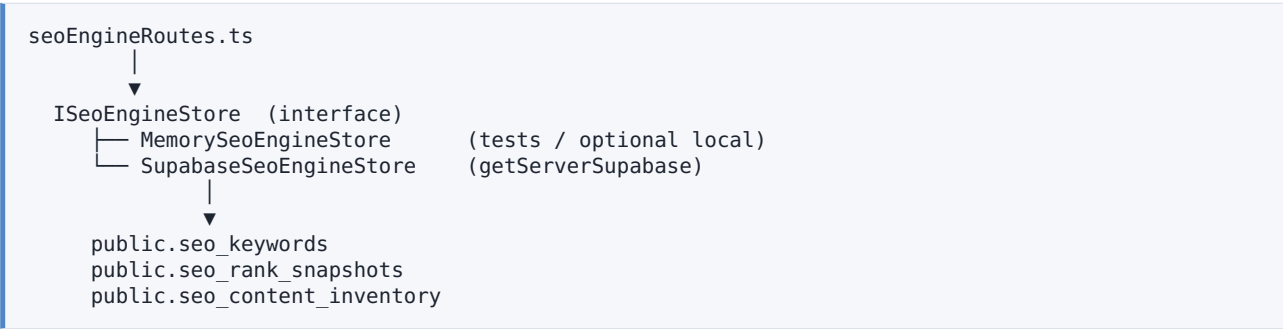
Schema-Drift (historisch, behoben)

Schicht	source -Werte
TypeScript / API	search-console , manual-import
SQL (nach Align)	search-console , manual-import

estimated ist aus dem CHECK entfernt; API lehnt Non-Canonical ab.

Bekannte Domain-/Schema-Lücke (nicht blockierend für Store-DoD): Domain-Felder notes und sourceRef haben **keine** DB-Spalten. Memory speichert sie; Supabase-Adapter persistiert sie nicht. Follow-up nur bei Bedarf, eigene Migration + Owner-Gate.

3. Architektur (geliefert)



Privilege-Separation (ADR-0043-Linie):

- Publishable/Anon **nie** für SEO-Writes
- Production: assertPrivilegedSupabaseConfigured / Factory fail-closed

4. Implementierungsschritte — Status

Schritt	Inhalt	Status
A	Schema align + RLS harden	Repo + Prod
B	Store-Abstraktion	PR #335
C	Router async + 503	PR #335

Schritt	Inhalt	Status
D	Unit/Contract-Tests	PR #335
E	Owner Production Gate	FK RESTRICT + Ledger
F	ADR-Nummerierung	ADR-0082

5. Definition of Done (WP-S1)

- [x] Source-Enum SQL $\equiv$ API (kein `estimated`)
- [x] RLS enabled + keine anon/authenticated Write-Policies
- [x] `ISeoEngineStore` + Memory + Supabase Adapter
- [x] Routes nutzen Store; Production fail-closed ohne privileged key
- [x] Unit/Contract-Tests (Source-Reject, unknown keyword, empty ranks)
- [x] `docs/seo/S1_SEO_ENGINE.md` Status aktualisiert
- [x] ADR finalisiert und nummeriert — **ADR-0082** (Kollisionscheck nach PR #345)
- [x] Production apply + Evidence **vollständig** (FK RESTRICT + Ledger) — angewendet 2026-08-15, Evidenz in `docs/runbooks/SEO_WP_S1_LEDGER_RECONCILIATION.md`

6. Risiken & Stop-Conditions

Risiko	Maßnahme
Shared Migration Zone	Nur <code>seo_*</code> Tabellen; keine globalen Auth-Tabellen
Privilege fallback auf Anon	Factory + <code>assertPrivileged</code>
Doppelte IDs Memory vs UUID	Domain <code>id</code> als string; DB <code>uuid</code> $\rightarrow$ string
Stille Rank-Invention	CHECK + API reject + Tests
CASCADE löscht Rank-Historie	FK RESTRICT Migration (applied)

STOP bei: Scope-Drift in Shared Zone, fehlender Owner-Approval für Prod-Apply, Request nach `estimated`-Ranks.

7. Nicht in diesem WP

- Search Console MCP (WP-D5)
- Prerender (WP-S2)
- Content-Generate (WP-N1)
- AdSense (WP-R1)
- Documentary Event-Emission (optional follow-up)
- `notes` / `source_ref` Spalten (optional follow-up)

8. Nächste Aktionen

1. ~~Apply `20260815220000_seo_rank_snapshots_fk_restrict.sql` auf AIFINANCIAL~~ — erledigt 2026-08-15
2. ~~Ledger-Abgleich laut `docs/runbooks/SEO_WP_S1_LEDGER_RECONCILIATION.md`~~ — erledigt 2026-08-15
3. ~~ADR-Draft nummerieren~~ — **ADR-0082 Accepted** (2026-08-16)
4. ~~WP-S1 als VERIFIED markieren in Roadmap~~ — in diesem Docs-PR
5. Nächstes Code-WP: **WP-D1 / D2 / D3** (JSON-LD, Title/Meta, Soft-404)

Siehe `docs/seo/HANDOFF_WP_S1_NEXT_2026-08-15.md` und `docs/adr/ADR-0082-seo-engine-platform-module.md`.

CAPITAL-AI — Video 01: SocialMedia API Schnittstellen in 5 Minuten anbinden

Quelle: docs/social-media/VIDEO_01_SOCIAL_MEDIA_API_INTEGRATION_5MIN.md

CAPITAL-AI — Video 01: SocialMedia API Schnittstellen in 5 Minuten anbinden

Dokumenttyp: Video-Produktionsvorlage / Tutorial-Skript

Zielmedium: YouTube / TikTok / LinkedIn / X / interne Produktdokumentation

Ziellänge: ca. 5:00 Minuten

Zielgruppe: Entwickler, Technical Founder, DevOps/Platform Engineers, FinTech-Produktverantwortliche

Status: Vorlage für die erste Aufnahme

Produkt: CAPITAL-AI

Scope: OAuth- und Direct-Publishing-Architektur für YouTube, TikTok, Instagram, Facebook und X

1. Ziel des Videos

Das erste Video soll nicht jede Plattformkonfiguration vollständig erklären. Ziel ist, in fünf Minuten die Architektur und den praktischen Integrationsablauf verständlich zu zeigen:

1. Welche SocialMedia-Plattformen CAPITAL-AI unterstützt.
2. Warum keine SocialMedia-API direkt aus dem Browser aufgerufen wird.
3. Wie ein Plattformkonto über den serverseitigen OAuth-Flow verbunden wird.
4. Wie Tokens sicher gespeichert und Konten dem verifizierten Benutzer zugeordnet werden.
5. Wie ein Publish-Request von CAPITAL-AI an die jeweilige Plattform weitergereicht wird.
6. Welche Konfiguration weiterhin in den externen Developer-Portalen und in Render erforderlich ist.
7. Welche Sicherheits- und Governance-Grenzen für eine FinTech-Plattform gelten.

Das Video soll insbesondere zeigen, dass CAPITAL-AI **keine Fake-Verbindungen und keine simulierten Publish-Erfolge** verwendet. Ein Konto gilt erst als verbunden, wenn der echte OAuth-Callback abgeschlossen und das Token serverseitig gespeichert wurde.

2. Technischer Ist-Stand, auf dem das Video basiert

Die bestehende CAPITAL-AI-Implementierung unterstützt folgende Plattformen:

- YouTube

- TikTok
- Instagram
- Facebook
- X

Der produktive Backend-Pfad liegt unter:

```
/api/social-media
```

Wichtige Endpunkte:

```
GET /api/social-media/access
GET /api/social-media/accounts
GET /api/social-media/auth/url?platform=<platform>
GET /api/social-media/auth/callback
POST /api/social-media/accounts/toggle
POST /api/social-media/publish
GET /api/social-media/history
```

Die Verbindung eines Kontos erfolgt ausschließlich über den OAuth-Flow:

```
CAPITAL-AI
  |
  | GET /api/social-media/auth/url?platform=tiktok
  v
CAPITAL-AI Backend
  |
  | erzeugt OAuth state + Authorization URL
  v
TikTok / YouTube / Meta / X
  |
  | Benutzer meldet sich an und bestätigt Scopes
  v
/api/social-media/auth/callback
  |
  | code + state werden serverseitig validiert
  v
Token Exchange
  |
  | verschlüsselte Token-Persistenz
  v
Account = CONNECTED
```

Ein Client darf ein Konto **nicht** über einen einfachen Request als verbunden markieren.

3. Kernbotschaft des Videos

„CAPITAL-AI behandelt SocialMedia-Anbindungen wie eine echte Enterprise-Integration: OAuth und Tokens bleiben serverseitig, jede Verbindung gehört zu einer verifizierten Benutzeridentität und ein Publish-Status wird nur dann ausgegeben, wenn die jeweilige Plattform-API tatsächlich verarbeitet wurde.“

Diese Aussage kann als Hauptthese zu Beginn und als Zusammenfassung am Ende verwendet werden.

4. Zeitplan für das 5-Minuten-Video

Zeit	Abschnitt	Ziel
00:00–00:20	Hook	Problem und Nutzen in einem Satz
00:20–00:55	Architekturüberblick	Plattformen + Backend-Grenze
00:55–01:40	OAuth-Flow	Konto verbinden
01:40–02:25	Render / Secrets	Environment-Variablen erklären
02:25–03:20	Publish-Flow	Wie Posting technisch abläuft
03:20–04:05	Security / FinTech Governance	Warum diese Architektur nötig ist
04:05–04:40	Plattformbesonderheiten	TikTok, Meta, YouTube, X
04:40–05:00	Zusammenfassung / nächstes Video	Abschluss + Ausblick

5. Vollständiges Sprecher-Skript

00:00–00:20 — Hook

Bildschirm

- CAPITAL-AI Dashboard öffnen.
- Bereich „Social Media Accounts“ oder entsprechende Integration zeigen.
- Kurz die Plattform-Icons einblenden.

Sprechertext

„In diesem Video zeige ich in fünf Minuten, wie CAPITAL-AI externe SocialMedia-APIs sicher anbindet. Unterstützt werden YouTube, TikTok, Instagram, Facebook und X. Wichtig dabei: Wir speichern keine API-Secrets im Frontend und simulieren auch keine verbundenen Konten. Jede Verbindung läuft über einen echten serverseitigen OAuth-Prozess.“

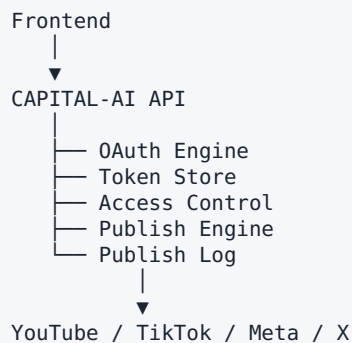
Texteinblendung

OAuth 2.0
Server-side Tokens
No Fake Connections
Direct Publishing

00:20-00:55 — Architekturüberblick

Bildschirm

Ein einfaches Diagramm einblenden:



Sprechertext

„Das Frontend spricht niemals direkt mit den SocialMedia-Providern. Alle externen Zugriffe laufen über das CAPITAL-AI-Backend. Dort befinden sich Access Control, OAuth-State-Management, Token-Persistenz, die Publisher und das Publish-Logging. Das verhindert, dass Client-Secrets oder Access-Tokens im Browser landen.“

„Die API ist unter `/api/social-media` eingebunden. Jeder funktionale Endpunkt verlangt eine verifizierte Nutzeridentität. Zusätzlich ist die SocialMedia-Funktion derzeit auf Owner- beziehungsweise Founder-Zugriffe begrenzt.“

00:55-01:40 — Konto über OAuth verbinden

Bildschirm

1. SocialMedia-Account-Seite öffnen.
2. TikTok als Demo wählen.
3. Netzwerk- oder API-Ablauf optional rechts daneben zeigen.

Sprechertext

„Nehmen wir TikTok als Beispiel. Wenn ein Nutzer auf ‚TikTok verbinden‘ klickt, ruft CAPITAL-AI zunächst `/api/social-media/auth/url?platform=tiktok` auf.“

„Das Backend prüft zuerst Authentifizierung und Berechtigung. Danach wird ein OAuth-State erzeugt und serverseitig gespeichert. Erst dann erhält der Browser die echte Authorization-URL von TikTok.“

„Nach Login und Consent leitet TikTok zurück auf `/api/social-media/auth/callback`. Der Callback akzeptiert die Benutzeridentität nicht aus einem Query-Parameter. Sie wird aus

dem vorher persistierten OAuth-State rekonstruiert. Danach tauscht der Server den Authorization Code gegen ein echtes Access-Token aus.“

Einblendung

```
state ≠ optional  
state = Bindeglied zwischen Benutzer und OAuth Callback
```

01:40-02:25 — Environment Variablen in Render

Bildschirm

Render Dashboard → Environment öffnen.

Wichtig: Werte der Secrets im Video vollständig ausblenden.

Sprechertext

„Damit dieser Flow funktioniert, benötigt jede Plattform ihre Client-ID und ihr Client-Secret. Diese Werte liegen ausschließlich als Environment-Variablen in Render.“

Einblendung

```
YOUTUBE_CLIENT_ID  
YOUTUBE_CLIENT_SECRET  
  
TIKTOK_CLIENT_ID  
TIKTOK_CLIENT_SECRET  
  
INSTAGRAM_CLIENT_ID  
INSTAGRAM_CLIENT_SECRET  
  
FACEBOOK_CLIENT_ID  
FACEBOOK_CLIENT_SECRET  
  
X_CLIENT_ID  
X_CLIENT_SECRET
```

Sprechertext

„Die Redirect-URI ist für alle Plattformen einheitlich aufgebaut und zeigt auf `/api/social-media/auth/callback`. Sie muss exakt genauso im jeweiligen Developer-Portal hinterlegt werden.“

Einblendung

```
https://capital-ai.online/api/social-media/auth/callback
```

„Fehlt ein Credential-Paar, bleibt die Plattform fail-closed. Der Server liefert dann keinen Fake-Erfolg, sondern meldet, dass der Provider nicht konfiguriert ist.“

02:25-03:20 — Publishing

Bildschirm

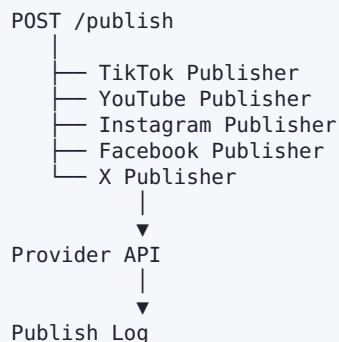
- Ein vorhandenes Video / Asset auswählen.
- Zielplattform wählen.
- Caption zeigen.
- Button „Sofort veröffentlichen“ zeigen.

Sprechertext

„Nach erfolgreicher Verbindung kann ein Publish-Request an `/api/social-media/publish` gesendet werden. CAPITAL-AI lädt zuerst das verschlüsselt gespeicherte Konto des eingeloggten Nutzers.“

„Für jede ausgewählte Plattform wird der passende Publisher verwendet. Caption, Hash-tags, Titel und Media-URL werden serverseitig in das jeweilige Providerformat übersetzt.“

Diagramm



Sprechertext

„Das Ergebnis wird anschließend im Publish-Log gespeichert. Ein Status wie ‚published‘, ‚scheduled‘, ‚draft‘ oder ‚failed‘ stammt damit aus einem realen Backend-Prozess und nicht aus einer UI-Simulation.“

„Entwürfe und geplante Veröffentlichungen werden bereits persistent protokolliert. Ein vollständiger Queue- beziehungsweise Scheduler-Prozess für zukünftige Veröffentlichungszeitpunkte ist ein separater Ausbaupunkt.“

03:20-04:05 — Security und FinTech Governance

Bildschirm

Security-Layer als Grafik:

```
graph TD; A[Bearer Session] --> B[Verified Identity]; B --> C[Owner / Founder Authorization]; C --> D[Rate Limit]; D --> E[OAuth State Validation]; E --> F[Encrypted Token Store]; F --> G[Provider API]; G --> H[Persistent Publish Log];
```

Sprechertext

„Warum ist diese Architektur für eine FinTech-Plattform wichtig? Weil SocialMedia-Automation nicht außerhalb der bestehenden Identity-, Governance- und Audit-Schichten betrieben werden darf.“

„CAPITAL-AI prüft deshalb Authentifizierung und Autorisierung vor dem OAuth- und Publish-Prozess. OAuth-State schützt den Callback vor Manipulation. Token werden serverseitig gespeichert. Publish-Aufrufe werden rate-limited und jeder reale Vorgang wird protokolliert.“

„Der SocialMedia-Layer darf außerdem niemals Finanzscores oder Screening-Ergebnisse verändern. Er konsumiert Inhalte beziehungsweise Analysen, bleibt aber von der kanonischen Scoring-Engine getrennt.“

Einblendung

Social Media = Distribution Layer
Scoring Engine = Source of Truth

04:05-04:40 — Plattformbesonderheiten

Bildschirm

5 Plattformkarten nebeneinander.

Sprechertext

„Die Provider unterscheiden sich vor allem bei Berechtigungen und App-Reviews.“

„Bei TikTok werden Login Kit und Content Posting API verwendet. Der Scope für öffentliches Direct Posting kann einen App-Review erfordern.“

„Bei YouTube wird die YouTube Data API verwendet; Upload-Berechtigungen können ebenfalls eine Google-Verifizierung erfordern.“

„Instagram und Facebook laufen über die Meta-Plattform. Für Instagram Direct Publishing benötigt man typischerweise ein Business- oder Creator-Konto, das mit einer Facebook-Seite verbunden ist.“

„X verwendet OAuth 2.0 und PKCE. Der PKCE-Flow ist bereits serverseitig berücksichtigt.“

04:40-05:00 — Abschluss

Sprechertext

„Damit steht die Grundarchitektur: echte OAuth-Verbindungen, serverseitige Tokens, ein zentraler Publish-Layer und persistentes Logging für fünf Plattformen.“

„Im nächsten Video gehen wir eine Plattform vollständig durch – vom Developer-Portal über die Render-Variablen bis zum ersten echten Publish-Request.“

Abschlussbild

CAPITAL-AI
Enterprise FinTech + AI Orchestration

Next:
TikTok Developer Setup → OAuth → Content Posting API

6. Empfohlene Demo-Reihenfolge

Für das erste echte Plattform-Tutorial nach diesem Übersichtsvideo bietet sich TikTok an:

1. TikTok for Developers öffnen.
2. CAPITAL-AI App auswählen.
3. Login Kit zeigen.
4. Content Posting API zeigen.
5. Redirect URI prüfen.
6. Scopes erklären.
7. `TIKTOK_CLIENT_ID` und `TIKTOK_CLIENT_SECRET` in Render zeigen — Werte verdeckt.
8. Render Deploy abwarten.
9. CAPITAL-AI öffnen.

10. TikTok verbinden.
 11. OAuth Consent zeigen.
 12. Account-Verbindung überprüfen.
 13. Testvideo auswählen.
 14. Publish starten.
 15. Publish-History prüfen.
-

7. Aufnahme-Checkliste

Vor Beginn der Aufnahme prüfen:

- ☐ Produktionsdomain ist erreichbar.
 - ☐ `/healthz` liefert erfolgreich.
 - ☐ Testkonto ist angemeldet.
 - ☐ SocialMedia-Zugriff ist für das verwendete Konto freigeschaltet.
 - ☐ Mindestens ein Provider ist vollständig konfiguriert.
 - ☐ Redirect URI stimmt im Providerportal exakt überein.
 - ☐ Browser enthält keine sichtbaren Passwörter oder Tokens.
 - ☐ Render-Werte werden während der Aufnahme ausgeblendet.
 - ☐ Developer-Portal zeigt keine Client-Secrets.
 - ☐ Demo-Medien enthalten keine vertraulichen Finanzdaten.
 - ☐ Datenschutz-/AGB-Seiten sind öffentlich erreichbar, falls der Provider sie im Review prüft.
-

8. Was im Video niemals gezeigt werden darf

Folgende Inhalte müssen geschwärzt oder vollständig außerhalb der Aufnahme bleiben:

```
*_CLIENT_SECRET
SUPABASE_SECRET_KEY
SUPABASE_SERVICE_ROLE_KEY
STRIPE_SECRET_KEY
OAuth Access Tokens
OAuth Refresh Tokens
Authorization Header
Bearer Tokens
Session Tokens
API Keys
Encryption Keys
```

Auch kurz sichtbare Secrets gelten als kompromittiert und müssten anschließend rotiert werden.

9. Technische API-Demo mit Browser DevTools

Optional kann während des Videos im Network-Tab gezeigt werden:

```
GET /api/social-media/access
```

Erwartete semantische Antwort:

```
{
  "success": true,
  "allowed": true,
  "reason": "...
}
```

Danach:

```
GET /api/social-media/auth/url?platform=tiktok
Authorization: Bearer <REDACTED>
```

Im Video darf nur die Struktur, niemals der echte Bearer-Token gezeigt werden.

Nach erfolgreichem OAuth:

```
GET /api/social-media/accounts
```

Damit kann gezeigt werden, dass das Konto erst nach dem echten Callback in der Account-Liste auftaucht.

10. Publish-Request als erklärende Darstellung

Für das Video kann folgender vereinfachter Payload gezeigt werden:

```
{
  "episodeId": "episode-001",
  "episodeTitle": "CAPITAL-AI Market Update",
  "targetPlatforms": ["tiktok", "youtube"],
  "publishType": "immediate",
  "mediaUrl": "https://example.invalid/video.mp4",
  "hashtags": ["FinTech", "AI", "Markets"]
}
```

Hinweis für die Aufnahme: Keine nicht existierende Media-URL als echten erfolgreichen Publish darstellen. Der Payload dient nur der Architektur-Erklärung. Für die reale Demo muss eine vom jeweiligen Provider erreichbare und zulässige Medienquelle verwendet werden.

11. Fehlerfälle, die im Video kurz erwähnt werden sollten

Provider nicht konfiguriert

```
HTTP 503  
Provider credentials missing
```

Bedeutung: Client-ID oder Secret fehlen serverseitig.

OAuth state ungültig

```
Callback rejected
```

Bedeutung: Der Callback kann keinem gültigen, vorher gestarteten OAuth-Vorgang zugeordnet werden.

Keine Berechtigung

```
HTTP 401 / 403
```

Bedeutung: Session ungültig oder SocialMedia-Funktion nicht für den Nutzer freigegeben.

Konto nicht verbunden

```
Publish failed: no connected account
```

Bedeutung: Es existiert kein gültiger persistierter Plattformaccount für den Nutzer.

Provider Review nicht abgeschlossen

Die API kann technisch funktionieren, aber der Provider kann Veröffentlichung, Sichtbarkeit oder Scopes einschränken.

12. B-Roll / Grafiken

Empfohlene zusätzliche Bilder für Schnitt und Übergänge:

1. CAPITAL-AI Dashboard.
2. Social Media Accounts Screen.
3. OAuth-Popup.
4. Render Environment-Seite mit geschwärzten Werten.
5. TikTok Developer Dashboard.
6. Google Cloud API Console.
7. Meta Developer Dashboard.

8. X Developer Portal.
 9. vereinfachtes OAuth-Sequenzdiagramm.
 10. Publish-Pipeline.
 11. Security-Layer.
 12. Publish-History.
-

13. Thumbnail-Ideen

Variante A:

5 Social APIs
1 FinTech Backend

Variante B:

TikTok + YouTube + Meta + X
mit EINER API-Schicht

Variante C:

OAuth richtig bauen
für Enterprise Apps

Keine API-Keys, Tokens oder Developer-Portal-Secrets im Thumbnail zeigen.

14. Titelvorschläge

1. **5 SocialMedia APIs in eine Enterprise-App integrieren | CAPITAL-AI Architektur**
 2. **TikTok, YouTube, Instagram, Facebook & X per OAuth anbinden — in 5 Minuten erklärt**
 3. **SocialMedia API Architektur für FinTech SaaS | OAuth, Token Store & Direct Publishing**
 4. **So verbindet CAPITAL-AI TikTok, YouTube, Meta und X sicher mit dem Backend**
-

15. Videobeschreibung — Vorlage

In diesem Video zeige ich die SocialMedia-API-Architektur von CAPITAL-AI.

Unterstützte Plattformen:

- YouTube
- TikTok
- Instagram
- Facebook

- X

Themen:

- OAuth 2.0
- serverseitige Token-Verwaltung
- sichere Redirect-Callbacks
- Direct Publishing
- Publish Logging
- Render Environment Variables
- FinTech Security & Governance

Wichtig: Im Video werden keine echten Secrets oder Access-Tokens veröffentlicht.

Dieses Video dient der technischen Dokumentation der CAPITAL-AI-Plattform und stellt keine Finanzberatung dar.

16. Kapitelmarken

00:00 SocialMedia APIs in CAPITAL-AI
00:20 Enterprise Architektur
00:55 OAuth Account Connection
01:40 Render Environment Variables
02:25 Direct Publishing
03:20 Security & Governance
04:05 Unterschiede der Provider
04:40 Zusammenfassung

17. Folgevideo-Serie

Empfohlene Reihenfolge:

Video 02 — TikTok

TikTok Developer App
→ Login Kit
→ Content Posting API
→ Site Verification
→ Redirect URI
→ Scopes
→ Render Secrets
→ OAuth Test
→ erster Publish

Video 03 — YouTube

Google Cloud Project
→ YouTube Data API v3
→ OAuth Consent Screen
→ youtube.upload
→ Render
→ Publish

Video 04 — Instagram / Facebook

Meta Developer App
→ Facebook Login
→ Instagram Graph API
→ Page + Business Account

- Permissions
- OAuth
- Publishing

Video 05 — X

- X Developer App
- OAuth 2.0
- PKCE
- Read/Write Permissions
- Render
- Publish

Video 06 — CAPITAL-AI SocialMedia Governance

- IAM
- Rate Limits
- Encrypted Tokens
- Audit Log
- Retry Strategy
- Provider Failures
- Scheduler

18. Definition of Done für Video 01

Das Video gilt als fertig, wenn nach fünf Minuten ein technisch versierter Zuschauer folgende Fragen beantworten kann:

- Welche Plattformen sind angebunden?
- Wo läuft OAuth ab?
- Wo liegen die Secrets?
- Warum darf der Browser die Provider nicht direkt aufrufen?
- Wie wird der OAuth-Callback einem Benutzer zugeordnet?
- Wie entsteht ein echter Publish-Status?
- Welche Funktion haben Render Environment Variables?
- Warum ist der SocialMedia-Layer vom Financial Scoring getrennt?
- Welche Schritte sind für eine konkrete Plattform im nächsten Video erforderlich?

Wenn diese Punkte verständlich vermittelt werden, erfüllt Video 01 seinen Zweck als Einstieg in die SocialMedia-API-Serie.